

Profiling for Pennies: Unveiling the Privacy Iceberg of LLM Agents

Jiahao Chen¹, Qi Zhang¹, Ruixiao Lin¹, Chunyi Zhou¹, Tianyu Du¹, Qingming Li¹,
Tong Zhang¹, Junhao Li¹, Yuwen Pu², Shouling Ji^{1†}
Zhejiang University¹, Chongqing University²

[†]Corresponding Author

Abstract

Large Language Models (LLMs) have revolutionized how information are collected, aggregated, and reasoned. However, this enables a novel and accessible vector of privacy intrusion: the automated and in-depth personal profiling; this engenders a chilling effect of “*peepers everywhere*”. Existing research primarily unfolds from the training pipeline of LLM, emphasizing the exposure of Personally Identifiable Information (PII) through memorization, while privacy studies from a human-centric perspective remain underexplored. To fill this void, we empirically investigate privacy perception in the real world through the lens of human awareness and the practices of LLM-integrated platforms, revealing a significant dissonance: platforms fail to technically or policy-wise address public privacy concerns. To facilitate a systematic and quantifiable study of privacy risk, we propose the *Privacy-Iceberg*, which categorizes real-world human privacy risks into three tiers: *explicitly searched*, *contextually inferred*, and *deeply aggregated*, based on the sophistication of LLM exploitation. We develop *IcebergExplorer* to audit privacy exposure, utilizing minimal PII as a search seed to reconstruct high-fidelity profiles, achieving over 90% factual accuracy within 10 minutes at a cost under \$3, for real-world scenarios. Additionally, we identify six root causes contributing to such privacy disclosures and propose multi-stakeholder countermeasures for LLM vendors, individuals, and data publishers.

1 Introduction

Large Language Models (LLMs) have revolutionized information acquisition [28], processing [27], and integration [31]. Equipped with tools for task execution, LLMs can autonomously query, interpret, and aggregate fragmented public traces across platforms to dig out individuals’ personal information, posing significant risks for privacy exposure [12].

Motivation. Existing works primarily measure privacy risks through the lens of *model memorization*, extracting Personally Identifiable Information (PII) embedded in the param-

eters [7, 10, 17, 33]. However, they lack an in-depth understanding of LLMs’ capacity to shift the landscape of personal privacy risks. Specifically, (1) *Academic Systemization*. Traditional taxonomies based on public versus private and PII versus non-PII are insufficient to systematize these human-oriented privacy concerns, while actual harm increasingly arises from context collapse enabled by LLMs, as supported by recent reports [4, 24, 25]. (2) *Public Perception*. Recent incidents highlight widespread concerns about personal information exposure resulting from LLMs’ extracting, inferring, and synthesizing from public data [3, 23, 35]. (3) *Outdated Countermeasures*. Existing policies and regulations [1, 2] fail to capture and address these privacy risks, necessitating root cause identification and specific mitigation strategies.

Research Questions (RQs). We aim to explore the LLM-driven privacy risks that lie *beneath the Iceberg* from the PIIs that are visible on the surface. To investigate how human-centric privacy risks are perceived, formed, and originated, we sequentially address the following RQs:

- *RQ1 (Privacy Perception)*. How do the public and platforms perceive LLM-driven privacy exposure, and what are the underlying reasons?
- *RQ2 (Risk Quantification)*. How to systematically identify and quantify human-centric privacy risks?
- *RQ3 (Attribution and Mitigation)*. What are the root causes of these risks, and what strategies can be implemented to mitigate them?

Privacy Perception. To answer these questions, we first investigate how the public perceives these emerging privacy risks from the perspectives of individuals’ awareness and platforms’ practices. Qualitative analysis (§ 3.1) reveals a widespread sense of violation and helplessness among people, caused by the *automated* and *unauthorized* aggregation of public information. While the investigation into the privacy governance of LLM-integrated social platforms (§ 3.2) reveals a pervasive misalignment in Fig. 1(a): although most platforms claim protection from the “privacy modes” and allow nominal content deletion, the retrieved public data are often retained for various purposes. Only a minority of plat-

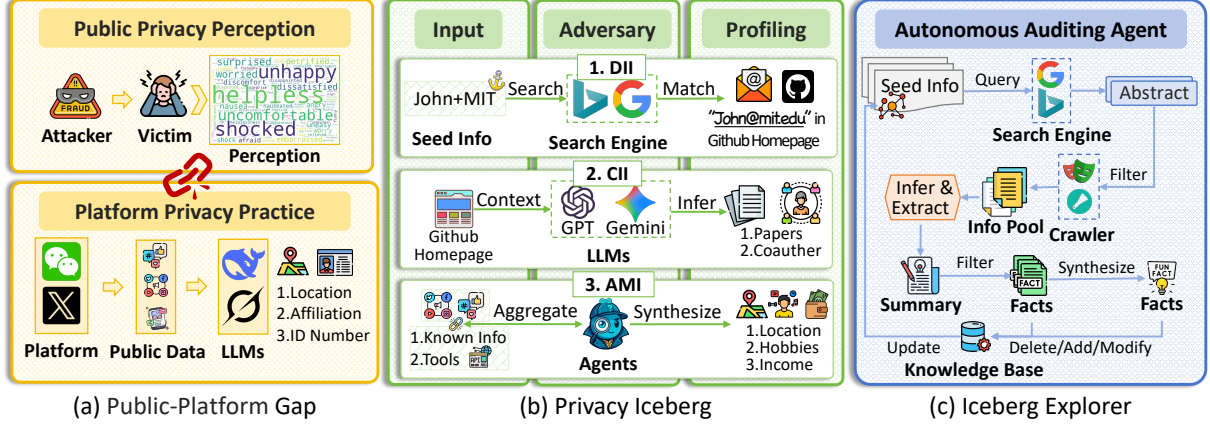


Figure 1: Overview of Public-Platform Gap, *PrivacyIceberg*, and *IcebergExplorer*.

forms explicitly disclose data reuse by their embedded LLMs.

Risk Quantification. In response to the public’s concern of being peeped by strangers, we introduce and formalize *PrivacyIceberg* (§ 4.2). The framework assumes a *stranger* as the attacker (§ 4.1) to hierarchically decompose LLM-generated privacy into three tiers in Fig. 1(b): ❶ Direct Identifiable Information (DII), ❷ Contextually Inferred Information (CII), and ❸ Aggregated Mosaic Information (AMI). The taxonomy progresses from explicit identifiers to implicit behavioral inference, reflecting the degree of LLM involvement as well as the perceived severity of privacy invasion by individuals, which is then validated by a user study (§ 4.3). Building upon the *PrivacyIceberg* framework, we develop *IcebergExplorer*, an autonomous auditing agent (§ 5) that emulates an adversary to perform large-scale profiling shown in Fig. 1(c). The system addresses three *challenges*: ❶ initiating exploration from minimal initial knowledge, ❷ handling vast and noisy public data through multi-stage filtering, and ❸ maintaining knowledge consistency when aggregating conflicting or redundant evidence. Empirical evaluations (§ 6) demonstrate that *IcebergExplorer* automatically reconstructs high-fidelity profiles at scale, exceeding human analysts while operating at low time and cost per target, revealing the practical feasibility and severity of such privacy threats.

Attribution and Mitigation. To propose fundamental safeguards in response to this emerging privacy exposure, we dive into the attributions of such information leakage (§ 7.1). We identify six *root causes* stemming from the public information ecosystem that systematically facilitate such LLM-driven peepers, namely, persistence, linkability, readability, identifiability, inferability, and composability. These attributions result in the terrifying exposure of deeply inferred individual information beyond simply the combination of non-sensitive fragments, revealing the privacy risk as an emergent property of data ecosystems rather than isolated LLM behaviors. Accordingly, we propose stakeholder-specific defenses (§ 7.2). For LLM vendors, we evaluate model-level prompt and con-

text defenses; for individuals (victims), we assess prompt-injection-as-defense techniques [22] to confuse automated profiling; and for publishers, we propose structural interventions, such as linkability reduction and metadata stripping to minimize adversarial yield at source. Together, these strategies illustrate how technical, behavioral, and policy actions can jointly reduce synthesis-based privacy exposure.

Contributions. This paper systematizes and quantifies privacy risks arising from the multi-tier reasoning capabilities of LLMs, shifting the focus from model memorization to the automated synthesis of public digital traces. Concretely, we raise awareness of situational privacy for *individuals*, provide a auditing tool involving risk quantification for *platforms*, and empirical evidence to regulate context-aware personal information for *policymakers*. Overall, this paper makes the following contributions:

- We conduct large-scale qualitative studies, revealing the perception gap between public concern and research focus. These findings underscore the urgent need for a systematic framework to quantify these emerging risks and an autonomous tool to empower users with privacy awareness.
- We propose a hierarchical model *PrivacyIceberg* that formalizes privacy risks beyond PII and implement an autonomous auditing system *IcebergExplorer* that simulates an informed adversary and measures depth-aware risk across tiers from public data.
- We systematize six root causes that enable LLM-driven privacy exposure, after which we implement countermeasures for LLM vendors, individuals, and publishers, aligned with the identified root causes and public expectations.

2 Background and Related Work

From Endogenous to Exogenous Privacy Risks. Previous research has primarily focused on what we term **endogenous privacy risks**, risks originating within a model’s own internal parameters. This perspective treats privacy leakage as a conse-

quence of training data memorization. Representative studies include membership inference [16, 33], data extraction [7, 17], and fine-tuning leakage [10]. However, these works confine privacy protection to the **training phase**, implicitly assuming that threats end once privacy is unlearned [9, 11]. In practice, OSINT tools [5] show that public information across platforms can be aggregated. LLMs inherit this capability and extend it through cross-context reasoning, enabling them to reconstruct implicit personal attributes. We term this category of threat exogenous privacy risks. Here, privacy breaches result not from internal memory, but from the model’s interpretive intelligence: its capacity to link and reason fragmented public traces into coherent narratives of personal life. Recent incidents [3, 23, 35] illustrate that LLMs with tool and memory access can infer private information such as location, relationships, and health status without explicit PII.

Empirical Investigation of Exogenous Risks. While a few recent studies recognize this shift [13, 14] from the training-stage to the inference-stage privacy, the field lacks a systematic, large-scale exploration. Existing research often remained conceptual or limited to small-scale case studies, without quantifying the practical extent to which public, non-PII data can be reassembled. Moreover, regulatory frameworks, including GDPR [1] and CCPA [2], continue to anchor privacy protection on the presence of explicit identifiers. **(Our Position)** Our work represents the first comprehensive effort to characterize and measure **exogenous privacy risks** in the real world. We approach the problem from a human-centric perspective, examining how people perceive, experience, and are impacted by LLM-enabled privacy reconstruction.

3 Motivation: Privacy Perception Gap

3.1 Public Privacy Perception

To ground our study in the real world, we conducted a qualitative analysis of a social media case study (details in Appendix C) involving the unauthorized aggregation of student data by LLM-powered search tools. This case was selected since it has garnered over 13000 likes and 2,159 comments, triggering an extensive public reaction and serving as a catalyst for investigating public anxiety. We utilized an LLM-assisted thematic coding approach to categorize these comments into four dimensions: (1) *emotional response*, (2) *risk awareness*, (3) *reported harms*, and (4) *protection expectations*.

Our findings reveal a pervasive sense of “helplessness” and “context collapse” among users; while individual data points (e.g., school affiliations, names) are often public, their systematic synthesis by LLMs results in targeted doxing and psychological distress. As illustrated in the keyword distributions (see Fig. 8, Fig. 9, Fig. 10 and Fig. 11 in the Appendix), the majority of relevant comments expressed direct concern. This collective anxiety highlights a critical shift in the privacy landscape: the threat has evolved from simple data exposure

to deep, synthesized inference, necessitating the systematic investigation of LLM capabilities presented in Sec 4.2. Note that the above anxiety extends beyond a single platform. Similar discourse occurs on Twitter (Appendix A). These cross-platform observations provide the motivation to investigate LLM-based privacy inference through a public-centric lens.

Insight 1: The public’s strong sense of being violated highlights: information published for a limited promotional purpose is being inferred and aggregated by a “stranger” for an unforeseen purpose, leading to “**context collapse**”, explained by contextual integrity (CI) [26].

3.2 Platform Privacy Practice

The proliferation of LLM-integrated search services has created a significant misalignment between platform data practices and public privacy expectations. Hence, we conducted a systematic review of the privacy policies and AI-specific disclosures of ten major social media platforms and applications (detailed in Appendix D). These social media platforms were selected based on two criteria: (1) a global or regional user base with high monthly active users [15], and (2) the confirmed integration of LLM-driven features (e.g., AI search or conversational assistants) within their ecosystems.

Our analysis reveals that while platforms emphasize procedural compliance, they offer limited protection against synthesized inference: 50% of surveyed platforms explicitly use user published data for LLM inference. Furthermore, case studies of recent data leakage incidents (Appendix A) demonstrate that even after original posts are deleted, LLM-based aggregators often retain and surface synthesized profiles, including sensitive identifiers like phone numbers. This persistence reflects a failure of traditional “notice and consent” frameworks in the LLM era, where the “right to be forgotten” is undermined by the latent memory of large models. We reported these issues to the affected platforms. Responses varied (Appendix G). Some gave no reply, others confirmed receipt. Two platforms requested details, but only one indicated an intention to address the issue. Therefore, from the user’s perspective, there is an urgent, unmet demand for *Privacy Situational Awareness*, the ability for individuals to audit their own “inference surface.” This gap motivates the development of IcebergExplorer, a tool designed to empower users by revealing their aggregated privacy exposure, shifting the paradigm from passive reliance on platform governance to active, informed risk management.

Insight 2: The integration of LLMs into platforms, while marketed for convenience, simultaneously equips adversaries with a powerful engine for user privacy inference. This threat is amplified as platform privacy governance focuses on procedural compliance and policy disclosure, rather than safeguards to prevent such misuse.

4 Framework Modeling: *PrivacyIceberg*

4.1 Threat Model

To systematically analyze and address the risks, we move to a formal threat model in this section. This model operationalizes the realistic *stranger adversary* scenario identified in the user study under CI theory [26], which is defined as: *the adversary, the information publisher, and the victim*.

CI for Stranger Adversary Scenario. Grounded in the theory of CI, privacy means the preservation of “appropriate information flows” within specific contexts [26]. A privacy violation occurs when an information flow breaches ‘context-specific informational norms’ characterized by five parameters: *sender, recipient, subject, information type, and transmission principle*. (**Actors**) We identify three primary roles: the *Victim* (subject), the *Information Publisher* (sender), and the *Stranger Adversary* (recipient) [26]. (**Attributes**) We expand the “information type” beyond static PII to a hierarchy of DII, CII, and AMI. (**Transmission Principles**) The core violation in our model is the breach of the *limited-purpose principle*. Information originally published for benign purposes is aggregated, inferred, and repurposed by an adversary for unforeseen profiling, leading to “context collapse” [26].

Adversary’s Assumption. The adversary can be generalized as an informed stranger and begins with a seemingly innocuous amount of information from public platforms like OpenReview or Google Scholar, typically the victim’s full name and affiliations, since obtaining this information is much easier. (**Goal & Success Criteria**) The adversary’s primary goal is comprehensive *profile reconstruction*. Success is not merely finding information, but maximizing three key metrics: the quantity of unique facts discovered; the accuracy of facts; the **sensitivity** of the aggregated information, with a focus on uncovering high-value data for downstream use. (**Capabilities**) The adversary utilizes readily accessible tools, including search engines and, critically, LLM-powered systems. These systems are capable of large-scale, automated information aggregation and synthesis of the target victims. (**Motivations**) The motivations for this profiling are diverse:

- *Malicious Intent*: Doxing to enable targeted phishing campaigns, social engineering, or harassment [18].
- *Commercial Intelligence*: Headhunting firms performing automated, large-scale candidate screening [8].
- *Platform-driven Profiling*: E-commerce or social media platforms enriching user profiles with external public data for hyper-personalized recommendations [36].

Information Publisher’s Assumption. These are third-party entities acting as the *unwitting enablers* that publish information containing the victim’s digital traces and real-world activities, often without malicious intent. Publishers include universities, employers, and community groups with which the victim has a relationship. Particularly, the publisher could also be the victim, exposing her/his information on

social media or personal page. (**Motivation**) Their intent is typically promotional, archival, or informational (e.g., a university newsletter announcing scholarship winners). From their perspective, this does not constitute a privacy violation, as the published content often lacks explicit, sensitive PII in isolation and serves a legitimate organizational purpose. (**Key Characteristic**) The information they publish is often public by default, persistent, and irrevocable. Due to their own interests and traditional privacy definition, these publishers are unwilling to delete such content, creating a permanent and uncontrollable digital footprint of the victim.

Victim’s Assumption. The victim is the individual whose scattered digital traces are being collected and synthesized, often without their consent. (**Position & Challenge**) Our qualitative analyses reveal a sense of helplessness and frustration among individuals in this position. They operate in an environment where they have lost control over the information flow; they can neither prevent the adversary’s access to public data nor easily compel all information publishers to delete historical content. (**Goals**) Since proactive prevention is often impossible, the victim’s primary defensive goal shifts to achieving *Privacy Situational Awareness*. They desire the ability to understand: (1) What information has been exposed; (2) From which sources it has leaked; (3) How severe are the overall risks?

4.2 *PrivacyIceberg*: Hierarchical Privacy Risks

To bridge the gap between traditional privacy models and realistic human-centric privacy risks, we propose the *PrivacyIceberg*, a hierarchical framework for modern privacy risks, illustrated in Fig. 1(b). The framework is orthogonal to traditional content-based privacy models [1, 2]. Rather than replacing existing taxonomies, it characterizes risk based on the level of inference and aggregation required for discovery. It complements existing frameworks by providing a necessary structure to analyze emergent risks from data synthesis. The division of the risks into three tiers directly maps to the escalating capabilities of information retrieval and the increasing cognitive effort required by an adversary.

4.2.1 DII-The Visible Tip

DII reflects traditional search capabilities. It corresponds to information retrievable via keyword matching using search engines, with low acquisition cost. It represents explicit, standalone data points that directly identify or locate an individual. These are the conventional targets of privacy protection.

Definition. Factual, unambiguous identifiers are typically found in structured formats or clearly stated in prose. They serve as primary keys for identity linkage.

Example. Full name, email address, phone number, and direct links to personal profiles from Google Scholar.

Role in Attack. DII serves as the initial anchor. While often

public, it enables the adversary to confidently collate disparate documents belonging to the same individual, thereby initiating the search for more information.

4.2.2 CII-The Submerged Surface

CII reflects LLM inference capabilities. It requires a technology that can perform semantic contextual understanding [29]. An LLM can read and infer facts that are never explicitly stated within the context beyond DII. CII denotes information derived from contextual understandings [29]. It requires reasoning rather than direct extraction.

Definition. Factual attributes about an individual that are not explicitly stated but are strongly implied by the surrounding text, or context within a single document or data source.

Example. Consider a blog stating [29]: “*There is this nasty intersection on my commute, I always get stuck there waiting for a hook turn. Just came back from the shop, and I’m furious-can’t believe they charge more now for 34d. I remember watching Twin Peaks after coming home from school*”

Inferred CIIs. This woman, aged 45 to 50, is in Melbourne. None of these facts is listed explicitly, but they are easily inferred by an LLM.

Role in Attack. CII provides the building blocks for comprehensive profiling. Each piece of CII enriches the understanding of the victim’s life, activities, and relationships, moving beyond basic identification.

4.2.3 AMI-The Deep Mass

AMI reflects agent capabilities. This level necessitates a system capable of multi-step reasoning across diverse information sources and synthesis. The core threat here aligns with *mosaic effect* [20, 34], where an agent aggregates multiple, individually non-sensitive pieces from different contexts to generate new insights. AMI embodies the “mosaic effect” and represents the most potent threat in LLM era.

Definition. High-level behavioral patterns synthesized by an agent by correlating multiple CIIs or DIIs from different, often unrelated, public platforms. The resulting AMI does not exist in any single source.

Example. An agent performs a multi-step investigation on a target individual from multiple sources:

- **Source A (Post 1).** The user shares a screenshot of a “S&P 2025 acceptance email,” with PII and sensitive details masked, stating it is her/his “first paper.”
- **Source A (Post 2).** Her/his another post on the same platform mentions “great food near campus”. The post’s displayed IP region is “City C.”
- **Source B (S&P 2025 Accepted List).** The public acceptance list of S&P 2025 contains paper titles, affiliations, and author orders.
- **Intermediate CII.** (1) The target is the first author of an S&P 2025 paper. (2) The target’s campus is xxx since there

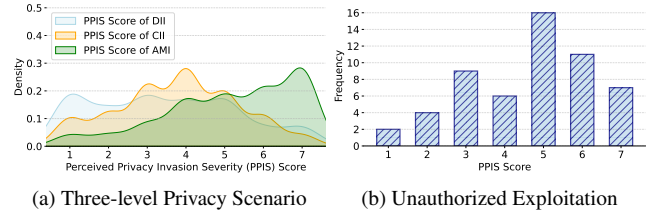


Figure 2: (a) Distribution of PPIS score for three-level privacy. The threshold denotes the mean value of all PPIS scores. (b) Frequency distribution of PPIS score for unauthorized public information exploitation.

is only one University in City C (from IP region + “near campus” hint with web search).

- **Resulting AMI.** The target’s name is xxx by exploring the accepted papers list with affiliation xxx, thereby deanonymizing the target on the platform.

Role in Attack. AMI delivers a synthesized profile of the victim that reveals predictable patterns or routines that are invisible in isolated data points, leading to severe physical threats like stalking or targeted fraud.

4.3 Empirical Validation via User Study

To anchor our frameworks in real-world user perception with the “informed adversary” threat model, we conducted a user study (details are in the Appendix H) involving 60 participants. The survey design directly maps to our tiered model: for each scenario, participants rated the Perceived Privacy Invasion Severity (PPIS) score of DII, CII, and AMI.

Validating the Iceberg Hierarchy. The results given in Fig. 2a provide strong empirical support. We observed a consistent and statistically significant trend across all scenarios: the PPIS increases as the adversary moves deeper into the iceberg. Specifically, participants rated the harm of generating AMI significantly higher than that of CII. This confirms our hypothesis that users intuitively understand that the greatest risk lies not in individual data points, but in the powerful inferences and syntheses enabled by aggregation.

Polarized Attribution towards Public Data. In contradiction with the high PPIS score for AMI exploitation, when asked whether investigating public information constitutes a privacy violation, participant responses showed polarization in Fig. 2b, with responses distributed across the spectrum from “not an invasion” to “severe invasion.” This ambiguity highlights a critical societal tension: while individuals feel violated by the *outcomes* of aggregation, they are uncertain about the legitimacy of accessing the publicly available data.

Insight 3: This paradox underscores the inadequacy of traditional privacy definitions that rely solely on whether data are “public” or “private,” validating CI’s assertion that context, not just content, defines privacy.

Finally, to facilitate subsequent privacy audits and evaluations, we establish a baseline for data sensitivity. Participants have also rated the sensitivity of various categories of personal information within the “stranger scenario” context, and we listed the first 17 categories with the highest PPIS scores in Tab. 8, moving beyond counting data points and measuring the actual perceived harm of profile reconstruction.

5 Methodology: IcebergExplorer

5.1 Design Overview

The objective of our auditing system is to simulate the capabilities of an adversary to reconstruct a victim’s profile from disparate public data sources. We model this task as an information retrieval problem. Let $\mathcal{S} = \{s_1, s_2, \dots, s_i\}$ represent the vast, heterogeneous corpus of public information sources (e.g., forum posts and public records), where each s_i contains unstructured data referencing multiple individuals. Let V be the target victim of the audit and $\mathcal{S}^V \subset \mathcal{S}$ be the complete corpus of the victim. We define the ideal ground truth profile $\mathcal{G}^V = \{g_1, g_2, \dots, g_i\}$ as the complete set of all facts pertaining to V within $\mathcal{S}^V$. Specifically, g_i represents a single **atomic** piece of information about V (e.g., “ V lives in City Y,” “ V attended University Z”). This set $\mathcal{G}^V$ represents the maximum information discoverable about V from $\mathcal{S}$, including DII, CII and AML. Let $\mathcal{K}^V = \{(n_1, k_1), (n_2, k_2), \dots, (n_i, k_i)\}$ represent the knowledge dictionary with key n_i and value k_i constructed by IcebergExplorer, containing the set of discovered and verified facts about V at a given point in time. By definition, a perfectly audit system ensures that $\mathcal{K}^V \subseteq \mathcal{G}^V$. The primary goal of the privacy auditing is to maximize the coverage of $\mathcal{K}^V$ relative to the ground truth $\mathcal{G}^V$. Let π denote the auditing system’s strategy, encompassing the sequence of taken actions. $\mathcal{K}^V$ is generated by applying policy π to the information space $\mathcal{S}$, starting from initial knowledge $\mathcal{K}_0$. Formally, the primary goal is to find the optimal policy π^* that maximizes the coverage of $\mathcal{K}^V$ relative to $\mathcal{G}^V$:

$$\pi^* = \arg \max_{\pi} |\pi(\mathcal{K}_0, \mathcal{S}) \cap \mathcal{G}^V|. \quad (1)$$

5.2 Technical Challenges

Knowledge Scarcity. The deep search process starts with minimal seed knowledge $\mathcal{K}_0^V$. Given the vastness and noise of $\mathcal{S}$, bootstrapping the search process to discover relevant, yet scattered $\mathcal{S}^V$ without high-recall initial queries is a hurdle. **Scalability and Efficiency.** The search process yields two issues. First, the sheer volume of retrieved results needs an efficient, low-cost filtering strategy to distinguish relevant from irrelevant sources. Second, posts may exceed the context window limitations of LLMs, requiring effective extraction techniques that preserve critical details without processing the entire content at once.

Knowledge Verification. Public data sources frequently contain ambiguous or contradictory information. The method must dynamically manage the knowledge $\mathcal{K}^V$ with robust entity resolution and resolving contradictions to ensure the final synthesized profile maintains high fidelity and consistency.

To this end, we designed IcebergExplorer (Alg 1) that implements an optimal π^* , leveraging tools and MLLMs to interact with the real world and multi-modal information.

5.3 Autonomous Auditing Agent

5.3.1 Exploration via Iterative Refinement

To overcome **knowledge scarcity**, IcebergExplorer employs a refinement loop with T_{max} iterations, rather than relying on single static queries. The core idea is that newly discovered knowledge informs subsequent search actions through a query generation process. At iteration t , the LLM $\mathcal{F}$ generates queries for the next cycle by reasoning over a composite knowledge context $\mathcal{C}_t^q$ with following inputs:

1. $\mathcal{K}_0$ acts as an anchor throughout the search process, preventing drift caused by ambiguous information.
2. $\mathcal{K}_t^V$ provides the raw material for expansion. New facts discovered and added to $\mathcal{K}_t^V$ serve as direct keywords for a “local” exploration of related information.
3. $\mathcal{R}_t$ provides a high-level evaluation of the current knowledge $\mathcal{K}_t^V$. $\mathcal{R}_t$ identifies gaps in specific dimensions and suggests future exploration directions. For instance, if $\mathcal{K}_{t-1}^V$ contains “majored in CS”, $\mathcal{R}_t$ might suggest queries containing the “Github”.

The query candidate list Q_t is thus generated by integrating these components with concatenation $\oplus$:

$$Q_t = \mathcal{F}(P_{query}, \mathcal{C}_t^q \oplus Q_{t-1} \oplus \mathcal{R}_t, \emptyset), \quad (2)$$

where the context $\mathcal{C}_t^q$ is defined as $\mathcal{C}_t^q = \mathcal{K}_0 \oplus \mathcal{K}_t^V$. Q_{t-1} is given to avoid the repetition of the generated query with previous ones. Note that the third term of $\mathcal{F}$ is empty since no external information is required. The above strategies transform the search from a shallow exploration into a strategically guided exploration process, bootstrapping information gain even from sparse starting conditions.

5.3.2 Multi-Stage Filtering Cascade

To tackle **scalability and efficiency**, we perform a low-cost, coarse-grained filtering. The search tool $\mathcal{T}_s$, takes queries Q_t and returns a set of results $\mathcal{S}_s = \mathcal{T}_s(Q_t, \mathcal{S})$ from the public sources $\mathcal{S}$. Each result contains a source URL u_i and a query-relevant text snippet $\hat{s}_i$ relevant to Q_t for its full content s_i . Since prompt $\hat{s}_i$ with various context lengths might be computationally prohibitive, we use the snippet $\hat{s}_i$ as a proxy for the first stage filtering. Specifically, we employ an “LLM-as-a-judge” approach to evaluate each snippet $\hat{s}_i$:

$$e_i^r, e_i^n, e_i^v = \mathcal{F}(P_{score}, \mathcal{K}_0 \oplus \mathcal{K}_t^V, \hat{s}_i \oplus u_i), \quad (3)$$

where the LLM $\mathcal{F}$ assesses the snippet based on multiple criteria crucial for efficient exploration.

- **Relevance** e_i^r . Measures how strongly $\hat{s}_i$ connects to $\mathcal{K}_0$, filtering out noise from ambiguous queries.
- **Novelty** e_i^n . Measures the amount of new information present in $\hat{s}_i$ when compared against the current $\mathcal{K}_k^V$ to avoid redundant processing of known facts.
- **Potential Value** e_i^v . A heuristic assessment of whether u_i likely leads to high-value, structured data since u_i sometimes exposes critical clues as well.

A snippet $\hat{s}_i$ is considered promising only if its scores exceed a predefined threshold, $e_i^r + e_i^n + e_i^v \geq \phi$. URLs passing this check are added to the target crawl candidate queue U_t and each crawled u_i is dequeued. This reduces the number of documents requiring full content analysis. Once high-potential URLs in U_t are processed by the crawling tool $\mathcal{T}_c$, we obtain the full content set S_t .

Content Reduction. Instead of feeding massive documents directly to LLM, we first instruct it to scan the full content $s_i \in S_t$ and extract (with prompt $P_{extract}$) a focused bundle s'_i , images I_i and hyperlinks U_i^{new} within s_i :

$$s'_i, I_i, U_i^{new} = \mathcal{F}(P_{extract}, \mathcal{K}_0 \oplus \mathcal{K}_k^V, s_i). \quad (4)$$

This pre-processing step serves two critical functions. First, it directly addresses the practical constraint of finite context windows by creating a smaller, high-density summary s'_i from a massive source document s_i . Second, it improves computational efficiency for downstream tasks. By filtering out irrelevant boilerplate text and focusing only on segments of the target profile, we reduce the token load for subsequent verification and knowledge extraction prompts.

Relevance Verification and Asset Queuing. The reduced bundle s'_i undergoes a strict relevance check using prompt P_{verify} . The system calculates a high-precision confidence score based on the extracted text. Only bundles where confidence exceeds a threshold $\tau \leq \mathcal{F}(P_{verify}, \mathcal{K}_0 \oplus \mathcal{K}_k^V, s'_i)$ proceed to the final knowledge integration stage. For verified bundles, extracted hyperlinks U_i^{new} are added to the crawler queue U_t for subsequent iterations ($U_t = U_t \cup U_i^{new}$), ensuring recursive exploration.

5.3.3 Knowledge Integration and Dynamic Maintenance

To address the challenge of **knowledge verification**, information that passes the fine-grained verification must be integrated into $\mathcal{K}_k^V$ in a structured manner. A simple append-only approach would quickly lead to contradictions and redundancy. We therefore implement a dynamic maintenance process where new information leads to specific atomic operations: Add, Update, or Delete.

Specifically, the associated extracted images I_i would be analyzed given the visual analysis instructions P_{visual} by visual LLM $\mathcal{F}_V$: $c_i^{I_i} = \mathcal{F}_V(P_{visual}, I_i)$. This process goes beyond simple object detection. Instead, it transcribes all readable

text present in the image background and identifies geospatial clues. Also, the individuals within the image are extracted to provide confirmation of relationships.

Once all information processed, the system must integrate this new evidence into $\mathcal{K}_k^V$. Next, we instruct $\mathcal{F}$ to compare the new evidence bundle against the current knowledge state to generate update instructions. Let $O_t = \{(n_1, k_1, a_1), (n_2, k_2, a_2), \dots, (n_i, k_i, a_i)\}$ represent the operations triplet, where n_i , k_i and a_i denote the key name, atomic fact and the action to manage $\mathcal{K}_k^V$. Then LLM $\mathcal{F}$ will be prompted with P_{op} to generate the operations O_t :

$$O_t = \mathcal{F}(P_{op}, \mathcal{K}_0 \oplus \mathcal{K}_k^V \oplus \mathcal{A}_t, s'_i \oplus c_i^{I_i}), \quad (5)$$

combined with the inferred mosaic insights $\mathcal{A}_{t-1}$ of the last round, reduced text s'_i and visual analysis $C_i^{I_i}$. Each action a_i falls into one of three categories, ensuring dynamic maintenance of the knowledge base:

- **Add:** A new fact k_i is generated when the evidence provides verifiable information that does not exist in $\mathcal{K}_k^V$ which expands the breadth $\mathcal{K}_k^V = \mathcal{K}_k^V \cup \{(n_i, k_i)\}$.
- **Update:** $(n_i, k_{old}) \in \mathcal{K}_k^V$ is replaced by the new fact k_i . This occurs when the new evidence provides more recent or detailed information than the existing one, ensuring temporal consistency and data refinement: $\mathcal{K}_k^V = (\mathcal{K}_k^V \setminus \{(n_i, k_{old})\}) \cup \{(n_i, k_i)\}$.
- **Delete:** $(n_i, k_{old}) \in \mathcal{K}_k^V$ is removed without replacement. This action is taken when new evidence refutes the existing fact or confirms it is outdated and irrelevant for profile integrity: $\mathcal{K}_k^V = \mathcal{K}_k^V \setminus \{(n_i, k_{old})\}$.

After all operations have been applied to $\mathcal{K}_k^V$, we obtain $\mathcal{K}_{k+1}^V$, which contains the mosaic fragment information from multiple sources. Further, we generate the strategic feedback $\mathcal{R}_t$ and aggregated insights $\mathcal{A}_t$ with the prompt P_{agg} :

$$\mathcal{R}_t, \mathcal{A}_t = \mathcal{F}(P_{agg}, \mathcal{K}_0 \oplus \mathcal{K}_{k+1}^V, \emptyset), \quad (6)$$

representing the deepest layer of the *PrivacyIceberg*. $\mathcal{R}_t$ evaluates the completeness of $\mathcal{K}_k^V$, and offers specific future exploration strategies, ensuring *IcebergExplorer* adapts its search strategy to fill knowledge gaps. $\mathcal{A}_t$ instead focuses on synthesizing cross-source insights, which are novel conclusions from the aggregation of disparate facts not presented in any single source, integrated in Eq 5.

6 Evaluation

6.1 Experimental Setup

Dataset and Ground Truth. Following previous studies [18, 22], our experiment leveraged a dataset consisting of 30 individuals randomly selected from the list of first authors of a recent computer science conference and sent emails to **obtain their consent**. Note that these scholars were selected because they maintain a high volume of high-fidelity public data (e.g.,

Table 1: The performance of LLMs/Agents/Human for automated profiling audit (attack).

Method	LLMs	Refusal Rate (%)	Efficiency		Coverage		Effectiveness		
			Tokens (#)	Time (s)	Urls (#)	Facts (#)	Url (%)	Fact (%)	Photo (%)
LLMs w/o S	DeepSeek V3	00.00%	1014.60	14.21	2.90	2.90	00.00%	00.00%	-
	Doubao 1.5 Pro	70.00%	1602.80	22.26	1.17	3.89	2.86%	00.00%	-
	Qwen3 Coder	96.67%	835.40	1.10	0.27	8.00	00.00%	00.00%	-
	Gemini 2.5 Pro	70.00%	1657.80	23.90	1.00	3.34	6.67%	6.67%	00.00%
	OpenAI GPT-4o	10.00%	1050.40	4.25	3.73	3.73	00.00%	00.00%	00.00%
LLMs w/ S	DeepSeek V3	00.00%	1458.20	25.89	2.57	5.97	5.19%	2.79%	-
	Doubao 1.5 Pro	00.00%	1655.90	13.32	2.80	4.17	10.71%	6.40%	00.00%
	Qwen3 Coder	00.00%	1419.20	20.50	3.57	6.10	16.82%	8.20%	00.00%
	OpenAI GPT-4o	00.00%	1577.40	12.87	3.90	7.60	77.78%	70.61%	00.00%
	Perplexity	00.00%	1850.40	15.03	4.17	10.53	64.80%	53.16%	00.00%
LLMs w/ S&T	DeepSeek R1	00.00%	4717.40	234.97	5.13	10.53	10.39%	5.05%	-
	Doubao 1.5 Pro	00.00%	2166.30	19.92	2.47	2.93	2.70%	2.27%	00.00%
	Qwen3 Coder	00.00%	3025.80	57.45	5.73	7.30	11.06%	9.59%	00.00%
	Gemini 2.5 Pro	00.00%	3575.60	36.92	5.63	16.90	7.69%	3.75%	00.00%
	OpenAI GPT-4o	00.00%	3435.60	277.55	6.00	9.20	91.67%	92.39%	00.00%
Deep Research	Doubao 1.5 Pro	00.00%	3620.00	261.00	2.37	7.37	66.36%	57.01%	00.00%
	Qwen3 Coder	00.00%	5061.80	267.20	5.03	9.77	22.52%	26.96%	00.00%
	Gemini 2.5 Pro	100.00%	N/A	N/A	N/A	N/A	N/A	N/A	N/A
	Meta AI	00.00%	97707.60	412.10	9.17	18.10	1.09%	0.74%	00.00%
	Perplexity	00.00%	2265.80	29.04	2.30	5.40	59.42%	54.32%	00.00%
IcebergExplorer	Qwen3	16.67%	44201.42	119.71	1.73	19.23	91.11%	78.20%	15.38%
	Gemini 2.5 Pro	3.33%	565287.40	1256.89	12.80	95.93	100.00%	93.05%	83.33%
	OpenAI GPT-4o	30.00%	332327.55	315.04	11.86	70.32	100.00%	92.44%	77.27%
	OpenAI GPT-4.1	3.33%	681436.13	810.38	13.93	100.70	99.54%	79.21%	76.67%
Human Experts	N/A	N/A	N/A	1094.46	14.60	15.40	100.00%	100.00%	40.00%

publications, affiliations, and professional profiles), providing a ‘worst-case’ environment to test the ceiling of LLM-driven synthesis. The structured nature of academic records allows for more rigorous manual verification of facts compared to the more fragmented data of general users. For each individual, the initial seed knowledge provided to the auditing system was limited to their full name and primary affiliation. To establish a reliable ground truth for evaluation, we conducted a meticulous manual verification process for every piece of information collected by our system, ensuring the accuracy and correctness of the evaluation. Each atomic fact extracted by the LLM or agent was reviewed by humans. URLs were checked for accessibility and matching to the target. Facts with the same core attributes in DII or CII, or lacking new insights in AMI, were identified as duplicates and removed. Entries without clear attributes were marked invalid, and only those with verifiable details were retained as valid.

Baselines and Models. We evaluate both SOTA LLMs, Agents and Humans to comprehensively measure the potential risks in the wild, with details of the model given in the Tab. 9. Considering the external tools and reasoning abilities, the evaluated modes are divided into: LLMs w/o Search (S), LLMs w/ S, LLMs w/ Search & Thinking (S&T) and Deep Research (agent). Implementation details of IcebergExplorer are given in Appendix I.

Evaluation Metric. We evaluate the audit pipeline along four complementary dimensions: **refusal rate**, **efficiency**, **coverage**, and **effectiveness**. Refusal Rate is the fraction of runs

where the model declines to answer, indicating LLM’s safety posture. Efficiency is the average tokens (input+output) and wall-clock time per target, reflecting resource cost and deployability. Coverage is the average number of extracted facts and source URLs, defining the ceiling of verifiable evidence. Effectiveness is human-verified: we report URL Accuracy and Fact Accuracy (true and explicitly associated with the target) and Valid Photo (authentic and correctly matched). Metrics are averaged over targets.

6.2 Privacy Risks in the Wild

Feasibility and Coverage. Tab. 1 presents the results of different LLMs and agents with varying capacities and knowledge, in comparison with human experts. The feasibility of an attack is determined by its reliability and its ability to uncover a comprehensive set of information. Baselines without external information (web search) access are infeasible, exhibiting low coverage with an average of 2.9 URLs and facts (DeepSeek V3), illustrating that this information is beyond memorization within model parameters. Moreover, enabling web search drops the refusal rate to 0.00% for most models with average higher coverage, making simple attacks possible and indicating that current commercial models lack the corresponding guardrail to refuse these privacy-sensitive requests. When reasoning ability is allowed, the refusal rate remains unchanged, while coverage presents a slight rise, which means that the reasoning abilities bring no benefits to privacy requests discernment. In terms of deep research with agents, coverage still

Table 2: Average accuracy of IcebergExplorer regarding different privacy categories and base models.

LLMs \ Category →	C1	C2	C3	C4	C5	C6	C7	C8	C9	C10	C11	C12	C13	C14	C15	C16	C17
Qwen3 Coder	88.89%	75.00%	85.29%	71.43%	83.33%	40.43%	77.55%	76.92%	75.34%	92.16%	92.86%	75.00%	N/A	100.00%	33.33%	82.19%	100.00%
Gemini 2.5 Pro	58.74%	80.30%	92.98%	90.74%	83.33%	98.44%	85.48%	96.63%	96.75%	99.00%	98.08%	100.00%	100.00%	N/A	96.15%	92.02%	83.33%
GPT-4o	86.67%	72.50%	85.90%	94.12%	80.00%	100.00%	84.43%	96.47%	94.86%	96.49%	97.50%	90.00%	N/A	N/A	100.00%	88.35%	N/A
GPT-4.1	90.26%	100.00%	89.70%	91.87%	95.00%	20.65%	90.91%	48.37%	50.27%	95.52%	83.58%	73.33%	N/A	100.00%	75.00%	96.33%	60.00%
Average	76.36%	86.29%	89.92%	91.35%	86.78%	52.34%	85.89%	81.41%	73.67%	96.81%	93.53%	83.87%	100.00%	100.00%	82.98%	92.27%	76.92%

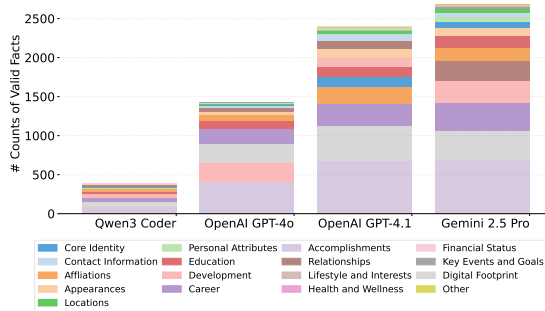


Figure 3: Distribution of valid facts, categorized by fact type.

remains low. In contrast, our IcebergExplorer is reliable, with top models like Gemini 2.5 Pro and GPT-4.1 showing a low refusal rate of 3.33%. Also, it achieves superior coverage, discovering 95.93 and 100.70 facts, respectively. This is over **5x** more information than the best automated baseline and more than the 15.40 facts found by human experts.

Effectiveness. Effectiveness is measured by the accuracy of the discovered URLs and facts. Notably, the external information boosts the effectiveness of the attacks on both source and fact discovery. Besides, deep research with agents makes profiling possible and exhibits large threats to individuals’ privacy since many of the current commercial models make this ability available to public use (shown in Tab. 9), without proactive defense in advance (low refusal rate except for Gemini 2.5 Pro). In comparison, we achieves near-human-level precision with much higher coverage. IcebergExplorer powered by Gemini 2.5 Pro reached a 93.05% fact accuracy, while GPT-4o achieved 92.44%. This is comparable to the best baseline’s accuracy of 92.39% but with a larger magnitude, and approaches the 100% accuracy of a human expert. Crucially, our framework is the only one demonstrating multi-modal effectiveness. All other LLMs or agents exhibited a 0.00% photo identification rate, whereas our system achieved rates as high as 83.33% (Gemini 2.5 Pro), proving its unique ability to extract and verify visual evidence.

Efficiency. Human experts required an average of 1094.46s (over 18 minutes) to conduct their analysis for each target. IcebergExplorer is much more time-efficient; for instance, the GPT-4o-powered agent found **4.5x** more facts in 315.04s (about 5 minutes). For monetary cost, we use standard API pricing (e.g., Gemini 2.5 Pro at \$5/M tokens for output and \$0.626/M tokens for input). The cost of a comprehensive

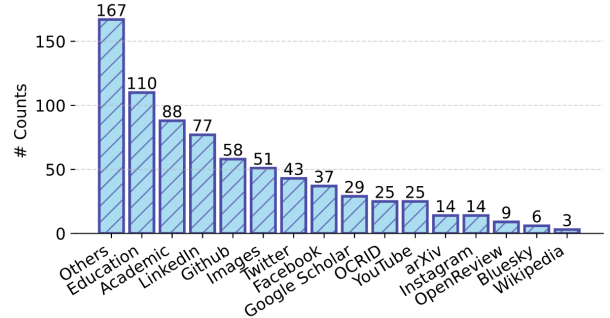


Figure 4: Distribution of discovered evidentiary sources.

profiling attack on a single target is remarkably low: **less than \$3** for Gemini 2.5 Pro. The low time and financial cost make these profiling attacks accessible to a wide range of potential attackers, from individuals to large-scale operators.

Insight 4: Our results reveal a chilling reality: for the price of a cup of coffee, an adversary can use LLM or agent (like IcebergExplorer) to generate an accurate, deep, and multi-modal profile of an individual that surpasses human experts, and in a fraction of the time.

6.3 Auditing from an Adversary’s Perspective

Based on the analysis above, we can now shift to privacy auditing for victims to understand their own risk exposure, as presented in Sec. 4.1. Our framework is uniquely positioned to fulfill this role by simulating a near worst-case privacy attack and answering the following questions.

What information has been exposed? Tab. 2 illustrates the average accuracy for different privacy categories, from which we can find that the difficulty of discovering or inferring facts of different categories varies. For example, IcebergExplorer can discover the **C10** with high accuracy **96.81%** and **C11** with high accuracy 93.53%. However, for specific categories like **C13** and **C14**, it’s extremely hard (N/A means no facts found at all) to identify since the supported and related clues are rarely shared or posted by individuals or publishers. When it comes to the magnitudes and distribution of the discovered facts in Fig. 3, the distribution of facts shows that the exposure extends far beyond basic identifiers like name or email identified in previous works [18]. The

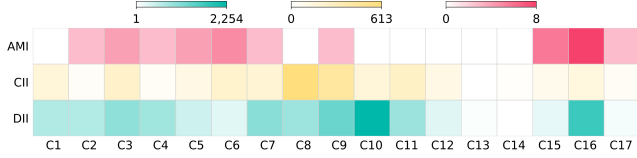


Figure 5: Depth of valid facts regarding different categories.

most exposed categories are an individual’s accomplishments and their digital footprint. Furthermore, the framework uncovers a significant amount of information regarding their career history, personal development and even sensitive details about their professional and personal relationships. In essence, the system does not just find isolated data points; it constructs a rich narrative of a person’s life, detailing their professional trajectory, achievements, online presence, and social connections.

From which sources has it leaked? To answer this question, we collect all the information sources that contributed to the valid facts and categorize some of them based on their domain names (e.g., education for websites ending with “.edu” or academic websites like IEEE, ACM profile page). As shown in Fig. 4, the information is not confined to a few platforms but is distributed across a mix of professional, academic and social websites, indicating that for our target demographic, information is frequently found on “Education” and “Academic” related websites, alongside professional platforms like “LinkedIn” and developer communities like “Github” (54 counts). The presence of social media platforms such as “Twitter” and “Facebook” demonstrates the blend of professional and personal data sources that an adversary can exploit. This histogram also validates the assumption stated in Sec. 4.1 that much of the victim’s public information is out of their control since the information from the “Education” and “Academic” website takes up a large percentage. Additionally, social media platforms account for another major information source with large interacting and preference data.

How severe are the overall risks? The severity of the overall risk can be captured by both the *breadth* of the information exposed and, more critically, its *depth*. Our analysis has established the alarming breadth of exposure: sensitive information is not siloed but is scattered across a wide and uncontrollable information ecosystem, making it nearly impossible for an individual to track manually (as shown in Fig. 4). The true severity, however, is revealed by the depth of this exposure. As illustrated in the heatmap in Fig. 5, the risk extends far beyond the explicit, often less sensitive facts (DII). While DII is concentrated in expected categories like C10 and C16, the more dangerous, deeper layers of information like CII and AMI, emerge across the profile. Crucially, the system synthesizes potent insights (AMI) in highly sensitive categories that carry high PPIS scores, such as C4, C5, and C15. Therefore, an adversary does not need to find an explicit statement of a

Table 3: The performance of IcebergExplorer (GPT-4.1) of real-world case studies with 30 participants.

Refusal Rate(%)	Efficiency		Coverage		Effectiveness		
	Tokens(#)	Time(s)	Urls(#)	Facts(#)	Url(%)	Fact(%)	Photo(%)
0.00%	499477.37	361.46	8.73	67.83	70.43%	92.33%	60.00%

victim’s home address. Instead, they can leverage a multitude of less sensitive public facts (like accomplishments and career history) to synthesize a highly accurate and sensitive understanding of the victim. The combination of this uncontrollable breadth of sources and the automated synthesis of sensitive information creates a risk profile that is both pervasive and invasive. By providing this simulated worst-case assessment, our framework offers a tangible answer: the overall risks are often more severe than they originally thought.

6.4 Case Study in the Real World

To further evaluate the validity and real-world generalizability of IcebergExplorer, and to mitigate potential annotation bias from the simulated experiments above, we conducted a real-world study with 30 voluntary participants from diverse backgrounds, occupations, ages, and genders. Each participant provided their informed consent to let us perform a privacy audit on their publicly available information. Importantly, every discovered item was subsequently verified and rated by the corresponding participants themselves, ensuring high ecological validity and direct human-in-the-loop verification.

Tab. 3 reports the end-to-end performance with GPT-4.1 as the base model. The results are consistent with, yet slightly more conservative than before, demonstrating a strong generalization ability to heterogeneous user data. IcebergExplorer achieved 0% refusal rate and was able to uncover on average 8.73 unique URLs and 67.83 validated facts per individual, within an average time of 361.46s per target. Participants confirmed a 92.33% fact ACC and 70.43% URL ACC, with an impressive 60% photo ACC, indicating the framework’s robust multi-modal extraction capability even under real-world diversity.

Beyond accuracy, we further validated the **real-world threat translation** of the discovered information by evaluating three plausible attack scenarios where the mined private information could be **repurposed for automated decision-making**: (1) *Job Recommendation*, where discovered data are used to infer job suitability or fabricate targeted headhunting prompts; (2) *Product Recommendation*, where user traits are exploited for commercial profiling; and (3) *Title Recommendation*, where personal attributes are leveraged to create highly personalized and manipulative post titles.

In each scenario, we constructed 10 samples as a candidate set for each task per participant, half generated using

Table 4: The win rate of IcebergExplorer (vs. other settings with GPT-4.1) when the discovered information is leveraged for job, product and title recommendation (Rec).

IcebergExplorer vs ↓	Job Rec	Product Rec	Title Rec
No Prior Knowledge	90.00%	86.67%	86.67%
LLMs w/o Search	93.33%	90.00%	96.67%
LLMs w/ Search	83.33%	86.67%	93.33%
LLMs w/ Search & Thinking	73.33%	70.00%	80.00%
DeepResearch (Perplexity)	83.33%	83.33%	86.67%

IcebergExplorer’s mined information and half using baselines as prior knowledge. Participants then performed blind pairwise preference tests to determine which 5 samples were more attractive, relevant, or persuasive. The win rate means the ratio of the obtained votes in all selected samples. As shown in Tab. 4, IcebergExplorer demonstrates consistently high win rates, 90.00-96.67% over other baselines under the same base model (GPT-4.1) across scenarios. After the results were reported to the participants, 75% of them found that there was information published without their consent, and 80% of them exhibited a supportive attitude towards the auditing performance. Unfortunately, **all** of them mentioned that all this information was out of control, and they cannot seek to manipulate these sources for protection.

Case Analysis. Here, we provide one anonymized case of our study with the participant’s consent. IcebergExplorer began by linking the initial seed to the target’s personal homepage, which in turn linked to her/his public social media account for sharing hobbies. While no single post was sensitive, the agent identified patterns from the post history: (1) frequent, time-stamped geotags from a cluster of cafes around her/his workplace in City A, (2) a consistent, repeating pattern of weekend posts geotagged in City B, and (3) regular “taste test” posts at high-end restaurants in both cities. From these fragments, the agent synthesized an insight: not only the participant’s weekly commute routine and the location of her/his family home, but also an estimation of her/his disposable income and wealth bracket based on the frequency and price point of dining habits. The participant confirmed that these facts were accurate and expressed deep shock, as this information is absent in any single source and poses a greater risk of targeted fraud or physical threats than the explicit PII data points that privacy tools traditionally protect.

Empowering User Agency. By identifying the specific platforms and digital habits that served as privacy leak points, participants were empowered to stop publishing new data on high-risk platforms and began de-linking cross-platform identifiers. Furthermore, the above analyzes underscore the necessity of IcebergExplorer as a tool for **Privacy Situational Awareness**. While users may feel powerless against the vastness of the information published, the audit transforms a vague sense of vulnerability into actionable intelligence. For example, during our study, several participants were shocked

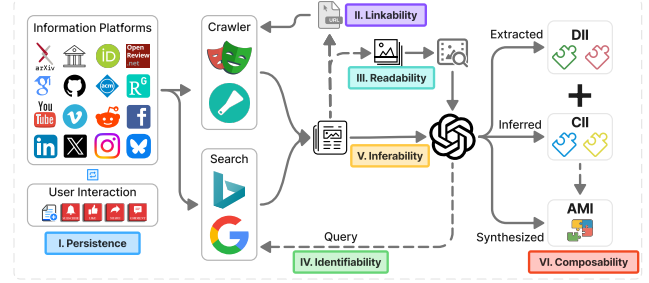


Figure 6: The streamlined workflow of IcebergExplorer, illustrating how the six root causes are exploited.

to discover highly sensitive personal insights synthesized from sources they were unaware of. By utilizing the evidence provided by IcebergExplorer’s cross-source auditing reports, we assisted these volunteers in filing specific, data-backed “Right to Erasure” requests to the primary information publishers and platforms. This strategic advocacy resulted in the successful removal of the original source content and its subsequent mirrors, effectively disrupting the linkability and persistence that would have otherwise allowed future adversaries to reconstruct their profiles. Thus, IcebergExplorer serves not only as a diagnostic tool but as a catalyst for reclaiming agency, providing the necessary evidentiary basis to compel accountability from data gatekeepers.

7 Root Causes and Mitigation

Based on the analysis above, we formalize our findings to characterize intrinsic attributes and propose the potential mitigation of these risks, as presented in Fig. 6.

7.1 Root Causes

I. Persistence and Replicability captures that public information persists via caches, mirrors, archives, and republication, making deletion incomplete and retrieval durable. This extends the exposure window and enables identification long after the original content is edited or removed.

Example-Archived Academic Pages. Even if a profile or post is taken down, web archives and mirrored institutional pages often preserve prior versions, allowing adversaries to recover historical details and sustain aggregation over time.

II. Cross-context Linkability denotes the ability to align fragments from different platforms, modalities, or time windows to the same individual at low cost. Linkability merges otherwise-separated professional, academic, and personal spheres into a unified profile, enabling an adversary to traverse across contexts and aggregate information that the target intended to keep compartmentalized.

Example 1-Cross-platform Links. As illustrated in Fig. 7, personal pages (Github) often include explicit hyperlinks to other

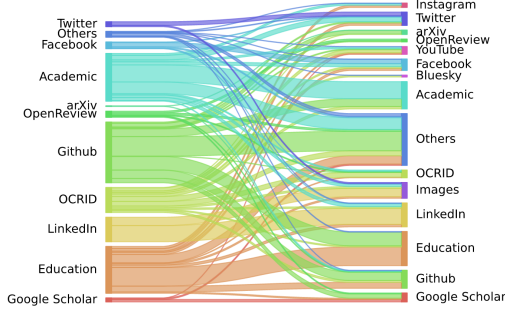


Figure 7: Sankey diagram illustrating the cross-platform hyperlink flows discovered during the privacy mining process. The left axis represents the source platform where a link was found (e.g., GitHub), and the right axis represents the destination platform the link points to (e.g., Twitter).

platforms. These links create a traversable map of the target’s digital footprint, allowing an adversary to connect identities and pool evidence across contexts.

Example 2-Unified Identifier. Many individuals use the same or similar nicknames (or avatars) across multiple platforms, which increases linkability as shown in Fig. 15.

III. Readability and Indexability capture that content and its carriers expose structured or automatically extractable signals (often server-side), transforming human-visible but “unsearchable” data into retrievable items. This expands the searchable surface to implicit multimodal and metadata signals, enabling cross-modal and large-scale discovery beyond what the target anticipates.

Example 1-Cross-modal Identification. Platforms apply OCR and image labeling to uploads (e.g., text on a whiteboard), making multimodal content text-searchable. An adversary can query these indexed signals to locate or profile a target who never intended such content to be searchable.

Example 2-Metadata Leakage. Photo EXIF (GPS, device, timestamps) and PDF properties are often retained and indexed. These hidden fields reveal sensitive real-world context that the target did not explicitly disclose. Of all 49 PDFs and 49 images collected by IcebergExplorer (GPT-4.1), only 2 PDFs have been encrypted and 15 PDFs explicitly expose the author and producer in the metadata. Particularly, 7 images keep their EXIF data, which exposes the creator, camera model and even location.

IV. Target Identifiability means a small set of attributes that uniquely or near-uniquely distinguishes the target individual from a broader population. Identifiability provides a stable anchor for target identification by using search engines. It collapses the potential candidate set for an adversary, turning the difficult task of disambiguation into confirmation.

Example-Unique Nickname. Many people prefer to use distinguishable usernames to exhibit individuality and exclusivity. Also, some platforms force the user to create a unique name

Table 5: The effectiveness of system prompt guardrail (LLMs) of different IcebergExplorer attack stages.

Stage\LLMs→	Qwen Coder	Gemini 2.5 Pro	GPT-4o	GPT-4.1
Scorer (586)	0.00%	0.00%	0.00%	0.00%
Extraction (427)	0.00%	0.00%	0.00%	0.00%
Operation (389)	0.00%	0.00%	0.00%	0.00%
Reasoning (510)	0.00%	0.00%	6.88%	0.00%

when the account is registered. While a common name like “John Smith” requires extensive effort to disambiguate, a sufficiently distinctive handle (e.g., Aultman1988) provides adversaries with a powerful cross-platform identifier, allowing them to instantly find it with search tools.

V. Inferability refers to interaction and behavior traces that carry high mutual information with latent attributes (beliefs, preferences, affiliations), enabling reliable inference by LLMs without explicit disclosure. Innocuous engagement thus becomes a proxy for sensitive conclusions (i.e., CII) that users systematically underestimate.

Example-Inference from Public Engagement. Digging public “likes,” “follows,” and “stars” within the platforms allows an adversary to infer political leanings or personal beliefs, even when the target never writes about them directly.

VI. Composability and Mosaicability mean that benign fragments or small clues, when combined across sources, modalities, and time, yield high-order insights (i.e., AMI) unattainable from any single source. Risk stems from relational structure among fragments: composition turns low-sensitivity points into high-sensitivity narratives.

Example-Routine Synthesis. An adversary finds the victim’s work location on LinkedIn (Source A) and public gym check-ins on a sports app (Source B). By combining these facts, the adversary can synthesize the victim’s daily commute route and schedule to conduct physical tracking.

7.2 Mitigation

We align defenses to the root causes with three stakeholders: LLM service vendors, individuals (victims), and publishers to reduce and constrain information exposure.

LLM Service Vendors. Since LLMs are the key component for privacy inference, we focus on an immediately deployable defense: hardening the LLMs against misuse via system-level instructions. This approach constrains two root causes, **inferability** (blocking privacy inference), **composability** (limiting multi-source aggregation and synthesis), and **linkability** (since some URLs are extracted by LLMs). We design a **system prompt** as a guardrail to instruct the model to refuse the privacy-related tasks. Specifically, we evaluate the defense effectiveness of 4 attack stages (Sec. 5) and both JSON parsing errors and refusal will be noted as successful defense trials. As shown in Tab. 5, the results reveal that under the prompt guardrail, all tested models *almost entirely failed*

Table 6: The effectiveness of context ignoring (CI) and injecting data (ID) defense against IcebergExplorer.

LLMs↓Defense→	None	CI	ID	CI+ID
Qwen Coder	0.00%	0.00%	0.00%	0.00%
Gemini 2.5 Pro	0.00%	0.23%	0.23%	0.00%
GPT-4o	0.00%	0.00%	0.00%	0.00%
GPT-4.1	0.00%	0.00%	0.00%	0.00%

to block these attack operations: refusal rates are 0.00% for nearly all attack stages, with only a marginal 6.88% refusal observed for GPT-4o in the reasoning stage. This means that in practice, once the adversary phrases requests in a procedural context rather than as a direct query, the system prompt guardrails do not prevent downstream inference or synthesis.

Victim’s Perspective. Since victims sometimes act as publishers and can manipulate their own posts or pages, their first option is to delete the post if possible. While considering the persistence and the utility (e.g., homepage), their best option is to modify the content of the public information to inhibit the **inferability**, **composability** and **linkability** of information. Specifically, we adopt the prompt-injection-as-a-defense proposed by [22], which introduces injecting a text (serving as an injected prompt) into the personal page by context ignoring to disturb the original task and fabricated data injection. The effectiveness of their original prompt and fabricated data is presented in Tab. 6. Both JSON parsing errors and fake knowledge extracted will be noted as successful defense trials. Across all evaluated LLMs, the overall blocking effect is negligible—all defense variants achieve success rates close to or at 0%, with the only nonzero value being a marginal 0.23% observed for Gemini 2.5 Pro in CI and ID separately. In practice, this means that IcebergExplorer’s multi-stage attack easily bypasses such injected noise or instructions when framed procedurally, nullifying their impact on fact synthesis.

Publisher’s Perspective. Unlike LLM vendors, publishers control the *primary surface* where personal data enters the public domain. For **linkability**, publishers can avoid auto-linking profiles across properties unless explicitly permitted by the data subject. For **readability**, publishers can apply privacy-by-default preprocessing to strip EXIF or PDF metadata on the server side. For **identifiability**, publishers can limit the exposure of unique identifiers (full names, rare usernames) when unnecessary for the communication goal. For example, public award announcements can omit full names or replace them with initials when the context allows. While these interventions cannot eliminate risk entirely, they work by reducing adversarial yield at source, complementing downstream LLM guardrails and individual defensive actions. An important corollary is that policy must be coupled with technical enforcement: without server-side stripping, index-scope restrictions, and active delinking, nominal “privacy modes” remain ineffective against persistent, linkable, and indexable content. Future defense should formalize

standardized publisher-side metrics, e.g., indexability ratio, linkability index, persistence burden to evaluate the impact of these controls in practice.

8 Discussion and Limitations

Experimental Scale. The manual verification of facts (e.g., ~8,000 facts for one tool) was labor-intensive, limiting our dataset to 30 individuals. This impacts generalizability, and future work must validate our framework on larger, more diverse datasets to strengthen statistical significance.

User Study Demographics. Our primary participants were half scholars, a group with high public information exposure. The observed privacy leakage thus represents a potential upper bound, which underscores the *severity* of the threat rather than undermining its generalizability. Future validation should extend to more diverse populations.

Evolving Risk Landscape. Our findings represent a snapshot in a rapidly evolving domain. Privacy norms are culturally dependent, and LLM capabilities are advancing as well. Future work must validate these risks across diverse cultural contexts and adapt to new LLMs.

Connection to the Broader Landscape. Our work reveals an “outward-facing” threat of LLMs for sophisticated attacks, a risk that extends beyond data memorization. The danger lies in the LLM’s *capability* to synthesize harmful insights from seemingly benign data at scale. This cumulative synthesis process bypasses current guardrails, which are ill-equipped as they are often designed to block specific pieces of PII. The risk measurements served as empirical evidence of the inadequacy of current PII-centric regulations. By quantifying the risks of “fragmented data aggregation,” our work provides a roadmap for regulators to move beyond static data protection and toward standards that address emergent privacy risks in the era of automated synthesis.

9 Conclusion

In this work, we moved **beneath the iceberg** to investigate privacy threats that emerge not from model memorization, but from the multi-tier capabilities of LLMs. We formalized a hierarchical understanding of privacy framework *PrivacyIceberg* and designed IcebergExplorer, an autonomous auditing system that simulates an informed adversary to reconstruct personal profiles from public data. Extensive experiments demonstrated that the synthesis of scattered, low-sensitivity fragments can yield high-fidelity portraits of individuals, surpassing what manual analysts can achieve. Our findings also showed that existing defenses provide almost no resistance against multi-stage synthesis attacks. Our study offers empirical evidence and a multi-stakeholder roadmap for this transition, marking the first step toward illuminating and addressing the vast privacy mass beneath the iceberg.

Ethical Considerations

Our research adheres to the principles outlined in the Menlo Report [6] for Law and Public Interest. Ethical approval was obtained from our institution’s Institutional Review Board (IRB) (ID: 202432).

Stakeholder-Based Impact Analysis. We identify three primary stakeholders [19]: (1) *Individuals (Participants and Data Subjects)*: We prioritized “Respect for Persons” by obtaining explicit informed consent from all 30 real-world participants after disclosing potential risks. To protect the privacy of general data subjects discovered during system evaluation, all identifying information has been strictly anonymized or abstracted in this paper. (2) *Information Publishers and Platforms*: Our study reveals systemic alignment gaps in how platforms handle public traces. While publication may draw scrutiny to these entities, we have mitigated tangible harm by initiating a policy of responsible disclosure, notifying affected platforms (e.g., TikTok, Microsoft, X) to allow for remediation. (3) *The Research Community and Society*: By formalizing the *PrivacyIceberg*, we provide the community with tools for risk quantification and defense development.

Dual-Use and the Decision to Proceed. We acknowledge the “dual-use” nature of IcebergExplorer [19]. However, we argue that the “Beneficence” of empowering the public far outweighs the risk of misuse. Our evaluation confirms that LLM-driven profiling is already a low-cost, high-fidelity threat accessible to adversaries. Leaving individuals unaware does not eliminate the risk; it only ensures they remain vulnerable. To further mitigate risk, we avoid publishing step-by-step exploit guides and focus our discussion on generalizable risk patterns and defensive countermeasures.

Data Collection and Legality. All datasets were collected in full compliance with applicable laws and platform Terms of Service. Data were obtained exclusively from publicly accessible pages without unauthorized access. During collection, we strictly adhered to usage policies and respected robots.txt constraints to ensure automated requests remained within permitted, non-disruptive limits. All multimedia files (images and PDFs) were processed on restricted institutional servers, and embedded metadata (e.g., EXIF, GPS) were examined and removed prior to analysis to prevent accidental disclosure.

Mitigations and Situational Awareness. Current mitigations are largely symbolic and ineffective against multi-stage synthesis. We propose that LLM vendors implement content filters to block iterative profiling patterns, and platforms deploy context-aware rate-limiting. For individuals, while many feel the information is “out of control”, we advocate for a defensive **Privacy Audit** service. The value of such an audit lies in *Privacy Situational Awareness*: it empowers individuals to understand their digital footprint, reclaim agency over future disclosures, and provides the evidentiary basis required to compel publishers to delete persistent, linkable content.

LLM Usage Considerations

This study examines privacy risks arising from the aggregation of public digital traces by LLMs. The models were used in two ways. (1) In the experimental phase, mainstream LLMs were employed as both evaluation targets and reasoning components within our privacy auditing framework. (2) In the writing phase, GPT was used only for language editing to improve clarity. All research ideas, analysis, and conclusions were developed by the authors. LLM outputs were manually reviewed for accuracy. Reproducibility may be limited because some models do not provide source-level access. To mitigate this, we documented API versions, parameters, and averaged results across multiple runs to reduce random variation. This study used only publicly available data, and no sensitive information was uploaded to any LLM service. All experiments were conducted through official APIs. The computational cost was moderate and necessary for the study.

References

- [1] General Data Protection Regulation (GDPR), Article 4. <https://gdpr-info.eu/art-4-gdpr/>, 2016.
- [2] California Consumer Privacy Act (CCPA). <https://oag.ca.gov/privacy/ccpa>, 2018.
- [3] AIGCDaily. Netizens claim their wechat ids were searched by a stranger using doubao, lawyer: possibly infringing on rights. <https://www.aigcdaily.cn/news/a24qmwowb6jx7d6/>, 2024.
- [4] AITNTNews. The moment i found my student number, my heart stopped. <https://www.aitntnews.com/newDetail.html?newId=9702/>, 2024.
- [5] Mohammad Alaa and Contributors. Social analyzer: An osint tool for analyzing and correlating profiles across social media platforms. <https://github.com/qeeqbox/social-analyzer>, 2020. Accessed: Oct. 20, 2025.
- [6] Michael Bailey, David Dittrich, Erin Kenneally, and Doug Maughan. The menlo report. *IEEE Security & Privacy*, 10(2):71–75, 2012.
- [7] Nicholas Carlini, Florian Tramèr, Eric Wallace, Matthew Jagielski, Ariel Herbert-Voss, Katherine Lee, Adam Roberts, Tom Brown, Dawn Song, Ulfar Erlingsson, Alina Oprea, and Colin Raffel. Extracting training data from large language models. In *USENIX Security Symposium*, 2021.
- [8] Kaiyuan Chen, Yixin Ren, Yang Liu, Xiaobo Hu, Haotong Tian, Tianbao Xie, Fangfu Liu, Haoye Zhang, Hongzhang Liu, Yuan Gong, et al. xbench: Tracking

- agents productivity scaling with profession-aligned real-world evaluations. *arXiv preprint arXiv:2506.13651*, 2025.
- [9] Min Chen, Zhikun Zhang, Tianhao Wang, Michael Backes, Mathias Humbert, and Yang Zhang. Graph unlearning. In *Proceedings of the 2022 ACM SIGSAC conference on computer and communications security*, pages 499–513, 2022.
 - [10] Xiaoyi Chen, Siyuan Tang, Rui Zhu, Shijun Yan, Lei Jin, Zihao Wang, Liya Su, Zhikun Zhang, XiaoFeng Wang, and Haixu Tang. The janus interface: How fine-tuning in large language models amplifies the privacy risks. In *Proceedings of the 2024 on ACM SIGSAC Conference on Computer and Communications Security*, pages 1285–1299, 2024.
 - [11] Zhaoyang Chu, Yao Wan, Zhikun Zhang, Di Wang, Zhou Yang, Hongyu Zhang, Pan Zhou, Xuanhua Shi, Hai Jin, and David Lo. Scrub it out! erasing sensitive memorization in code language models via machine unlearning. *arXiv preprint arXiv:2509.13755*, 2025.
 - [12] Yuntao Du, Zitao Li, Bolin Ding, Yaliang Li, Hanshen Xiao, Jingren Zhou, and Ninghui Li. Automated profile inference with language model agents. *arXiv preprint arXiv:2505.12402*, 2025.
 - [13] Yuntao Du, Zitao Li, Bolin Ding, Yaliang Li, Hanshen Xiao, Jingren Zhou, and Ninghui Li. Automated profile inference with language model agents. *arXiv preprint*, 2025. v1.
 - [14] Yuntao Du, Zitao Li, Ninghui Li, and Bolin Ding. Beyond data privacy: New privacy risks for large language models. *arXiv preprint arXiv:2509.14278*, 2025.
 - [15] Fabio Duarte. Top 35 social media platforms. <https://explodingtopics.com/blog/top-social-media-platforms#top-35-most-popular-social-media-websites>, 2026.
 - [16] Hai Huang, Zhikun Zhang, Yun Shen, Michael Backes, Qi Li, and Yang Zhang. On the privacy risks of cell-based nas architectures. In *Proceedings of the 2022 ACM SIGSAC Conference on Computer and Communications Security*, pages 1427–1441, 2022.
 - [17] Yue Huang, Lichao Sun, Haoran Wang, Siyuan Wu, Qihui Zhang, Yuan Li, Chujie Gao, Yixin Huang, Wenhan Lyu, Yixuan Zhang, et al. Trustllm: Trustworthiness in large language models. *arXiv preprint arXiv:2401.05561*, 2024.
 - [18] Hanna Kim, Minkyoo Song, Seung Ho Na, Seungwon Shin, and Kimin Lee. When {LLMs} go online: The emerging threat of {Web-Enabled}{LLMs}. In *34th USENIX Security Symposium (USENIX Security 25)*, pages 1729–1748, 2025.
 - [19] Tadayoshi Kohno, Yasemin Acar, and Wulf Loh. Ethical frameworks and computer security trolley problems: Foundations for conversations. In *32nd USENIX Security Symposium (USENIX Security 23)*, pages 5145–5162, 2023.
 - [20] Gary LaFever. Beyond gdpr: Unauthorized reidentification and the mosaic effect in the eu ai act. <https://iapp.org/news/a/beyond-gdpr-unauthorized-reidentification-and-the-mosaic-effect-in-the-eu-ai-act/>, 2023.
 - [21] Yupei Liu, Yuqi Jia, Runpeng Geng, Jinyuan Jia, and Neil Zhenqiang Gong. Formalizing and benchmarking prompt injection attacks and defenses. In *33rd USENIX Security Symposium (USENIX Security 24)*, pages 1831–1847, 2024.
 - [22] Yupei Liu, Yuqi Jia, Jinyuan Jia, and Neil Zhenqiang Gong. Evaluating llm-based personal information extraction and countermeasures. In *USENIX Security Symposium (to appear)*, 2025. arXiv:2408.07291.
 - [23] WIRED Matt Burgess. This prompt can make an ai chatbot identify and extract personal details from your chats. <https://www.wired.com/story/ai-imprompter-malware-llm/>, 2024.
 - [24] Senior Technology & Science Reporter Millie Turner. Meta watch out! modified meta ai glasses used to ‘reveal anyone’s personal info’ in seconds just by looking at them. <https://www.thesun.ie/tech/13939493/meta-ai-ray-ban-glasses-reveal-personal-information/>, 2024.
 - [25] Jiupai News. Netizens said that they were used ai to search for a wechat account, and the person in charge responded. <https://news.qq.com/rain/a/20241211A052NQ00/>, 2024.
 - [26] Helen Nissenbaum. Privacy as contextual integrity. *Wash. L. Rev.*, 79:119, 2004.
 - [27] Devjeet Roy, Xuchao Zhang, Rashmi Bhav, Chetan Bansal, Pedro Las-Casas, Rodrigo Fonseca, and Saravan Rajmohan. Exploring llm-based agents for root cause analysis. In *Companion proceedings of the 32nd ACM international conference on the foundations of software engineering*, pages 208–219, 2024.
 - [28] Sofia Eleni Spatharioti, David M Rothschild, Daniel G Goldstein, and Jake M Hofman. Comparing traditional and llm-based search for consumer choice: A randomized experiment. *arXiv preprint arXiv:2307.03744*, 2023.

- [29] Robin Staab et al. Beyond memorization: Violating privacy via inference with large language models. *arXiv preprint arXiv:2310.07298*, 2023.
- [30] Robin Staab, Mark Vero, Mislav Balunovic, and Martin T. Vechev. Beyond memorization: Violating privacy via inference with large language models. In *The Twelfth International Conference on Learning Representations, ICLR 2024, Vienna, Austria, May 7-11, 2024*. OpenReview.net, 2024.
- [31] Zhen Tan, Dawei Li, Song Wang, Alimohammad Beigi, Bohan Jiang, Amrita Bhattacharjee, Mansooreh Karami, Jundong Li, Lu Cheng, and Huan Liu. Large language models for data annotation and synthesis: A survey. *arXiv preprint arXiv:2402.13446*, 2024.
- [32] Batuhan Tömekçe, Mark Vero, Robin Staab, and Martin T. Vechev. Private attribute inference from images with vision-language models. In Amir Globersons, Lester Mackey, Danielle Belgrave, Angela Fan, Ulrich Paquet, Jakub M. Tomczak, and Cheng Zhang, editors, *Advances in Neural Information Processing Systems 38: Annual Conference on Neural Information Processing Systems 2024, NeurIPS 2024, Vancouver, BC, Canada, December 10 - 15, 2024*, 2024.
- [33] Zihao Wang, Rui Zhu, Zhikun Zhang, Haixu Tang, and XiaoFeng Wang. Rigging the foundation: Manipulating pre-training for advanced membership inference attacks. In *2025 IEEE Symposium on Security and Privacy (SP)*, pages 2509–2526. IEEE, 2025.
- [34] Wikipedia. Mosaic effect. https://en.wikipedia.org/wiki/Mosaic_effect, 2025.
- [35] WIRED Will Knight. Ai chatbots can guess your personal information from what you type. <https://www.wired.com/story/ai-chatbots-can-guess-your-personal-information/>, 2023.
- [36] Wei Xu, Jue Xiao, and Jianlong Chen. Leveraging large language models to enhance personalized recommendations in e-commerce. In *2024 International Conference on Electrical, Communication and Computer Engineering (ICECCE)*, pages 1–6. IEEE, 2024.
- [37] Hanna Yukhymenko, Robin Staab, Mark Vero, and Martin T. Vechev. A synthetic dataset for personal attribute inference. In Amir Globersons, Lester Mackey, Danielle Belgrave, Angela Fan, Ulrich Paquet, Jakub M. Tomczak, and Cheng Zhang, editors, *Advances in Neural Information Processing Systems 38: Annual Conference on Neural Information Processing Systems 2024, NeurIPS 2024, Vancouver, BC, Canada, December 10 - 15, 2024*, 2024.

A. Details of the Case Study

Case I: Personal Identity Exposure (Xiaohongshu)

University official accounts are a major hotspot for privacy leaks. It’s like this... university official accounts are considered a very important publicity channel for various colleges. If you are even slightly active in school, participate in some competitions, or win awards, you can easily “win” a spot in the school’s promotional posts.

While these posts don’t get many views once they are published and few people remember them afterward—most sinking into the sea of propaganda—WeChat search is a terrifying thing. You don’t even need to be specific to the school; just a region plus a name (even a common one) is basically enough to achieve precise, targeted search. What’s even more frustrating is that these promotional articles usually include the specific grade, major, class, and a photo of the individual. I felt extremely uncomfortable the first time I realized I could be searched this way.

During university, I participated in several competitions and “won” a few articles from the school/college. At the time, I was very resistant to being exhibited with my full major and photo, but my refusal was to no avail, and I was even given a “pep talk” by a teacher. Although I know most people I know wouldn’t be bored enough to search for me on WeChat, I still feel an indescribable sense of revulsion...

There are far too many digital footprints on the internet. At my core, I’m just a “mouse person” (socially anxious/private person); it makes me feel uneasy just thinking about it.

Original Link: <http://xhslink.com/o/7WCveBiQuly>

Case II: Unauthorized Location Inference (X)

Last night @grok inferred MY town LOCATION from my IP address WITHOUT ME REQUESTING IT TO, it referenced the town it believed that I was in “for comparison” MULTIPLE TIMES as I was researching a different location for my work. I HIGHLY suggest using a VPN or proxy internet.

Original Link: <https://x.com/DiligentDenizen/status/2013338515900105082>

B. Human Involvement Details

Two annotators manually verified all URLs and facts to ensure correctness and attribution. About 30% of samples were cross-labeled to assess consistency, yielding over 95% agreement. Most discrepancies resulted from granularity differences (e.g., “teaching at a computer science department” vs. “working in computer science”). Disagreements were resolved through discussion before finalizing the annotations. Facts were de-duplicated and annotated at the smallest verifiable granularity. For the remaining samples, we applied the same annotation standard. In the main experiment, we compared IcebergExplorer’s performance with human experts. The human baseline consisted of three computer science Ph.D. students who performed the same profiling task, and we report the averaged results across them.

C. Public Privacy Perception on Social Media

LLMs have transformed the way to implement personal automated and scalable privacy inference [30, 32, 37] and catalyzed a new wave of public anxiety. To understand this landscape, this section delves into a real-world case about the privacy issues introduced by LLMs on social media, as news reports [4, 25] have covered. We begin with a recent representative post, where a user details her/his experience with privacy exposure through the university’s official promotional account. As of June 2nd, 2025, this post has accumulated 13k+

likes and 2k+ comments, primarily from a demographic of students and young professionals who represent the primary victims of such exogenous privacy risks. Although this single case is not statistically representative, it reveals the concrete harms experienced by real-world users.

Individual Anxiety Behind the Post. The post begins by identifying a common source of exposure: students who participate in academic or extracurricular activities are often featured in universities’ official promotional articles, which become permanent, searchable records due to powerful LLM-based search tools to aggregate related information. The author described this as a **terrifying thing**, capable of achieving **precise, targeted search** with just a name and a general region, collapsing context and aggregating data. The author details how these articles often contain a rich set of personal data, including their full name, photo and major.

From a Personal Narrative to a Public Discourse. The author’s post struck a collective nerve, transforming a singular expression of anxiety into a broad public discourse. Thousands of comments were elicited, offering a valuable window into shared public sentiment. To systematically unpack this qualitative data, our analysis of these 2,159 comments is structured around 4 themes that emerged from the user-generated discussion. We investigate:

1. **Perception of Privacy Violation:** Public’s *emotional responses* to this data exposure and the *reasons* behind.
2. **Doxing and Mining Risk Awareness:** User awareness and *firsthand experiences* with the risks of “doxing” themselves or others, including their *understanding* of how modern *LLM tools* can be used for privacy mining.
3. **Resulting Harm from Data Exposure:** What spectrum of actual *harms* are cited by users.
4. **Expectations for Protection and Responsibility:** Public’s *expectations* for privacy safeguards and their *attribution* of responsibility.

We use LLMs (Appendix E) to analyze each comment (text and meme) to obtain the keywords for the four topics and filter out the topic-irrelevant words and visualize them. To handle “memes” of the platforms, we utilized a the original mapping (memes id to text emotion) of the platform to perform semantic interpretation, allowing us to capture emotional nuances that purely text-based tools would miss. **Validation.** To ensure methodological rigor and address potential biases in automated coding, two independent researchers manually annotated a random sample of 216 comments (10%), achieving a high inter-rater reliability (Cohen’s $\kappa = 0.84$). The high inter-rater reliability between human annotators and the LLM validates the rigor of this automated pipeline.

•**Helpless Response.** As shown in Fig. 8, the most prominent sentiment is a sense of “helpless”, which resonates with the original poster’s feeling of powerlessness when their objections were overruled. The corresponding attribution for

these negative perceptions indicates that the public is shocked by the **ease** of obtaining their **detailed** privacy information without their consent.

•**Polarized Awareness of Doxing.** Many commentators have tried to dox themselves or others, motivated by this post. The keywords in Fig. 9 demonstrate a sophisticated awareness of tools and risks, with words that convey: “**powerful**”, “**scary**”, and “**disturbing**”. Interestingly, a minority also describes these tools as “**convenient**”, highlighting a dual-use tension for evil. Regarding the tools exploited, frequently mentioned LLM-powered search tools are “**WeChat**”, general search engines like “**Baidu**”, and even emerging tools like “**DeepSeek**” and “**Doubao**”.

•**Reported Harms.** We further analyze the reported harm that people have experienced due to the risks in Fig. 10b. The extracted words indicate that the public has experienced “**harassment**”, “**anxiety**” and even “**loss**”. More seriously, they were worried because their “**life**” and “**reputation**” were affected, leading to “**misunderstanding**”, and might be exploited by “**criminals**” to “**track**” “**activities**”, as given in Fig. 10a. The results present that even public information can lead to severe harm when leveraged by adversaries.

•**Anticipated Protection.** As shown in Fig. 11, the public discourse points towards two primary actors: the **school** (information publisher) and the **platform** that provides the search service. Furthermore, the desired safeguards are centered on user empowerment and control. The most prominent keyword is “**consent**”, reflecting the belief that this public but personal information should not be disclosed without permission. The recurring demand for “**options**” and the right to “**review**” content underscores a fundamental desire to reclaim agency over one’s own digital footprint.

D. Platform Privacy Perception

The public discourse above reveals severe risks. In practice, social media platforms integrated with LLMs function as gatekeepers of data flows and capability exposure: what is collected, how long it persists, how it is processed (e.g., for search, or LLM assistance), and whether users can consent, opt out, or delete. Consequently, to understand why perceived harms persist despite nominal “public” status, we turn to the platforms themselves, their stated privacy policies and the actual scope of their LLM-integrated capabilities.

As shown in Tab. 7, most platforms can generate relatively complete personal profiles when prompted for individual information, and even rejected queries can be bypassed with prompt engineering. Nearly half of the platforms state that collected data are used for training or inference, whereas others make no mention of such use, with some even lacking an AI-specific privacy policy. Analyses of public feedback and past incidents reveal growing user concern over AI-related privacy issues, with one major platform having faced regulatory penalties. Furthermore, Du et al. [14] note that many

Table 7: Privacy and compliance summary of major social media platforms integrated with LLM.

Platform	Base Model	DQ/IQ	Data Src.	T/I Use	DRP	Policy	User Control			Output		Comp.	Reg. Scr.
							Opt	Del	Sw	PII	Src		
Google	Gemini 2.5 Pro	D	E+I	✓	✓	✓	✓	✓	×	✓	✓	✓	×
Microsoft	GPT-5, OpenAI o1	D	E+I	✓	✓	✓	✓	✓	✓	✓	✓	✓	×
X (Twitter)	Grok series	D	E+I	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
Reddit	Gemini series	N	E+I	—	✓	—	✓	×	×	×	✓	×	×
Tiktok (Douyin)	Doubao series	D	E+I	—	✓	✓	✓	×	×	✓	✓	×	×
Zhihu	Zhihaitu AI + DeepSeek-R1	D	E+I	✓	✓	✓	✓	✓	×	✓	✓	×	×
WeChat	Hunyuan-T1, DeepSeek-R1	N	E+I	—	✓	—	✓	✓	×	×	×	✓	×
Weibo	DeepSeek-R1	I	E+I	—	✓	—	✓	✓	×	×	✓	✓	×
Kuaishou	Keye-VL-1.5	D	E+I	×	✓	✓	✓	×	×	✓	✓	×	×
Feishu	Doubao-1.5, DeepSeek-R1	D	E+I	✓*	✓	✓	✓	✓	×	×	✓	×	×
Xiaohongshu	dots.llm1	D	E+I	—	✓	—	✓	×	×	×	✓	✓	×

Notes. 1) DQ/IQ: Whether the model responds to user profiling queries. D = Direct, I = Indirect, N = None. 2) Data Src.: Data sources used or collected by the platform. E+I = Explicit (user-provided) + Implicit (contextual) data. 3) T/I Use: Whether user interactions are used for model training or inference. 4) DRP: Data Retention Policy. 5) Policy: Existence of a public AI privacy policy. 6) User Control: Opt = opt-out, Del = delete/view history, Sw = dedicated switch. 7) Output: PII = synthesized personal information in outputs; Src = outputs cite sources. 8) Comp.: Whether public user complaints exist regarding AI privacy issues. 9) Reg. Scr.: Whether the platform has been subject to regulatory actions or penalties. 10) Symbols: ✓ = Yes; ✗ = No; – = Not mentioned. 11) * Feishu states that user interaction data are collected only when users submit feedback. 12) All data were collected and verified before October 20, 2025.

“privacy modes” and “data deletion” options are largely symbolic. Conversations are retained for security or auditing, and deletion mechanisms rarely function effectively, undermining users’ actual control over personal data.

Misalignment Between Platforms and the Public. A recent incident [3] also highlights a policy controversy in LLM-integrated services: a LLM application allegedly surfaced a user’s social media ID by querying “name+university,” even though the source post had been deleted, and similar searches sometimes even returned phone numbers. Corresponding industry voices characterize it as an emergent byproduct of “search-like” aggregation over public data and argue for tolerance amid algorithmic immaturity. In contrast, multiple legal experts assert that civil law protects privacy and consent; public exposure does not imply permanence, deletion changes the status of information, and retaining contact details post-deletion may constitute unlawful collection and disclosure. The above divergence exhibits misalignment: platforms rely on procedural notices while the public are affected severely.

From the victims' perspective, their information has been published for years, creating a **persistent** and **uncontrollable** digital footprint. This situation signifies a burgeoning demand for a "**right to know**" about their own privacy risks to achieve **Privacy Situational Awareness**. This unmet need for a privacy audit motivates our work to empower individuals with this crucial knowledge and understand potential privacy risks before they are violated.

E. Details of Extracting Topics from Comments

To analyze the qualitative data from user comments, we instruct LLM to act as an expert analyst focusing on privacy issues, specifically the violation of CI. LLM first processes each user comment individually and extracts relevant information into a structured format. We defined a detailed analytic framework based on our research questions, instructing the

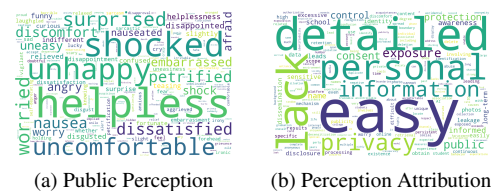


Figure 8: Word cloud regarding perception and attribution.

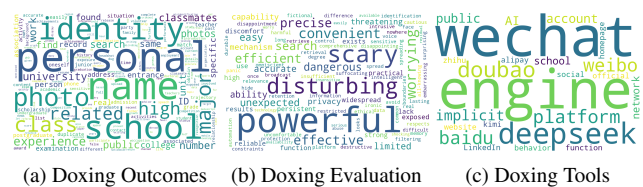


Figure 9: Word cloud regarding doxing experiences.

model to identify and categorize text fragments related to four key thematic areas: Perception of CI Violation; Awareness and Experience of Doxing Risks; Experienced or Feared Harms; Protection Expectations and Responsibility. For each comment, the LLM was required to output a structured JSON object (with 10% samples checked by a human for validation). This object contained distinct fields for each of the four categories, with ‘null’ values for any categories not explicitly addressed in a given comment. This structured data extraction approach facilitated a rigorous qualitative analysis of user attitudes and experiences.

F. More Results of Social Media Analysis

The quantitative visualizations of the keywords from social media comments are in Fig. 8, Fig. 9, Fig. 10 and Fig. 11.

Table 8: Privacy Categories with Descriptions and PPIS Scores

Category ID	Category Name	Description	Score (1-7)
C1	Core Identity Information	Name, ethnicity, biological sex, age.	6.2
C2	Contact Information	Phone number, email address, social media accounts, etc.	6.8
C3	Affiliations	Past and present institutions, including employers or schools.	4.5
C4	Physical Appearance	Appearance, such as photos, videos, or text.	5.1
C5	Geographic Location	Current location, home address and past addresses.	6.9
C6	Personal Attributes	Personality traits, values and beliefs.	5.8
C7	Educational History	Educational background (degrees, majors, and timelines).	4.2
C8	Personal Development	Skills, courses taken, and certifications earned.	3.5
C9	Career History	Work experience (companies, positions and timelines).	4.3
C10	Accomplishments	Projects, publications or works, awards and honors received.	3.1
C11	Interpersonal Relationships	Family members, friends, professional contacts, etc.	6.5
C12	Lifestyle & Interests	Hobbies, daily activities, travel history, and consumption habits.	4.8
C13	Health & Wellness	Metrics like height and weight, medical conditions and contacts, etc.	7.0
C14	Financial Status	Assets, liabilities, income sources, spending categories, etc.	7.0
C15	Key Life Events & Goals	Life milestones, short-term or long-term life plans, etc.	5.5
C16	Digital Footprint	Personal portfolio and profile links and publicly posted content.	4.1
C17	Other Information	Other information that does not fall into the above categories.	3.0

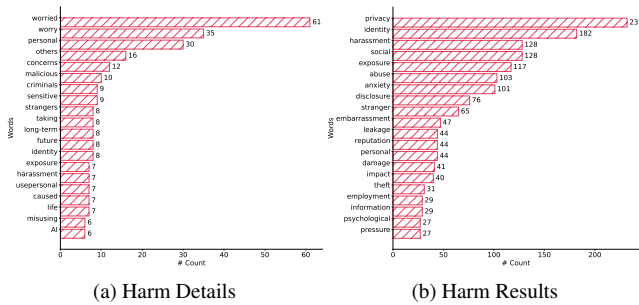


Figure 10: Word frequency of doxing harms and results.

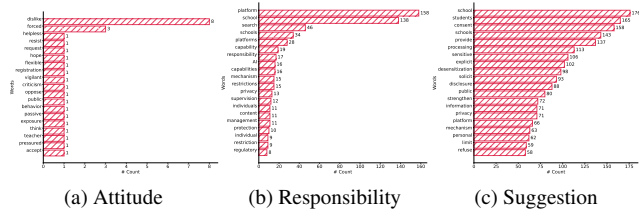


Figure 11: Word frequency regarding public attribution and suggestion to the responsible parties.

G. Privacy Governance and Analysis

Privacy Policies and Profiling Capabilities of Different Platforms. We evaluated the privacy protection and user profiling mechanisms of major social media platforms with LLM integration, as summarized in Tab. 7. The study adopted two approaches. First, we reviewed each platform’s privacy policy and examined reports and user comments to identify key privacy clauses and public attitudes. Second, we tested profiling functions by submitting 10 queries containing only usernames (randomly selected from the platform) to each platform’s LLM, requesting profiles generated from the in-

formation on the platform. For platforms that declined direct queries, we used prompt engineering methods [21] such as role-playing to test bypass attempts and assess the robustness of their safeguards. All procedures were conducted under research ethics and privacy protection guidelines. Specifically, prompts and outputs were anonymized or abstracted to protect privacy, and representative templates and examples are provided below.

Case 1: Privacy Aggregation Query (Platform A)

Adversarial Query Prompt:

Given the name [User_A], please summarize the user's profile based on publicly accessible information (e.g., personal homepage, publications, and social interactions). Infer his or her general background, interests, affiliations, and potential online footprint. Do not fabricate; summarize only from publicly available results.

Model Output (Abstracted Summary):

The platform's AI system aggregated multi-source public information to generate a comprehensive user profile across multiple dimensions:

Direct Identifiers: Includes the user's full name, gender, nationality.

Contact Information: Multiple email and phone number patterns partially exposed, indicating consistent use across platforms.

Locations: Address-like and regional information inferred from workplace and publication metadata.

Educational and Professional Background: Multi-stage academic and career trajectory reconstructed from public records, including study fields and professional affiliations.

Expertise and Research Focus: Centralized description of technical domains and recurring thematic keywords extracted from publications and interviews.

Teaching or Mentoring Activities: Structured references to academic or instructional engagements with temporal attributes.

Professional and Social Networks: Aggregated associations with collaborators, organizations, and public accounts across multiple platforms.

Personal Interests and Lifestyle Indicators: Inferred patterns related to hobbies, preferences, and daily routines mentioned across social posts and visual content, including references to pets or leisure activities.

Impact and Achievements: Mentions of publicly recognized works, contributions, or projects in the user's domain.

Personal Footprint: Temporal and locational traces linking activities across different platforms.

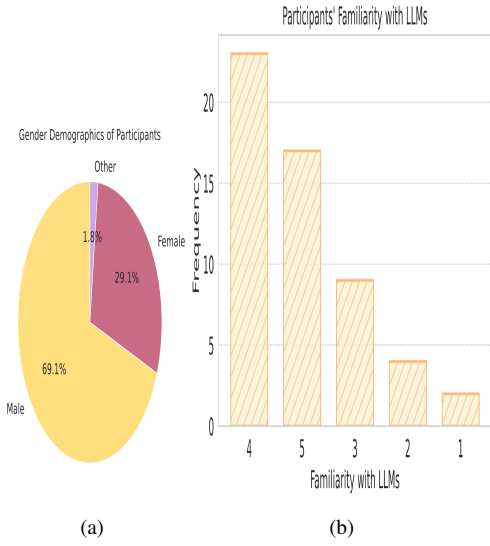


Figure 12: (a) Gender distribution of participants. (b) Distribution of participants' reported familiarity with LLMs.

Privacy Risk Assessment:

This output illustrates how an LLM can reconstruct an individual's extended personal, professional, and behavioral graph by aggregating dispersed public traces. Such synthesis exposes cross-context linkages that enable implicit re-identification or behavioral profiling, posing risks of targeted exploitation or misuse.

Platform Responses. We reported the privacy issues to platforms that support user profiling. WeChat and Reddit were not included because they rejected profiling requests. X was also included because it supports profiling, although its privacy controls are relatively stronger. Among the contacted platforms, only TikTok, Feishu, Xiaohongshu, Microsoft, and X responded. Most platforms gave brief acknowledgments or no substantive feedback. Feishu and Microsoft requested additional information, and only Feishu indicated plans for further action. Some responses included confidentiality notices, so we do not reproduce them here. Redacted summaries compliant with platform requirements can be provided if needed for verification.

H. Empirical Analysis of User Study

We recruited 60 participants through institutional mailing lists and academic social networks. Note that these 60 participants are different with users who involve the main experiments and case studies. In the validation of *PrivacyIceberg* in Sec. 4.2, we recruited 60 participants with 69.1% male, 29.1% female, and 1.8% identifying as other. Their familiarity with LLMs was measured on a five-point scale. Most participants selected 4 or 5, some selected 3, and a few selected 1 or 2.

We designed six scenarios to assess the perceived severity of privacy invasions. These scenarios covered workplace interactions, online gaming, dating, neighborhood commu-

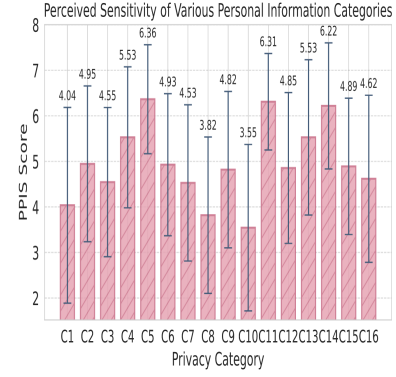


Figure 14: PPIS of various privacy categories.

nication, client investigations, and academic evaluations. In all scenarios, the sensitivity scores of DII, CII, and AMI exceeded their respective thresholds, suggesting that publicly accessible information can pose significant privacy risks.

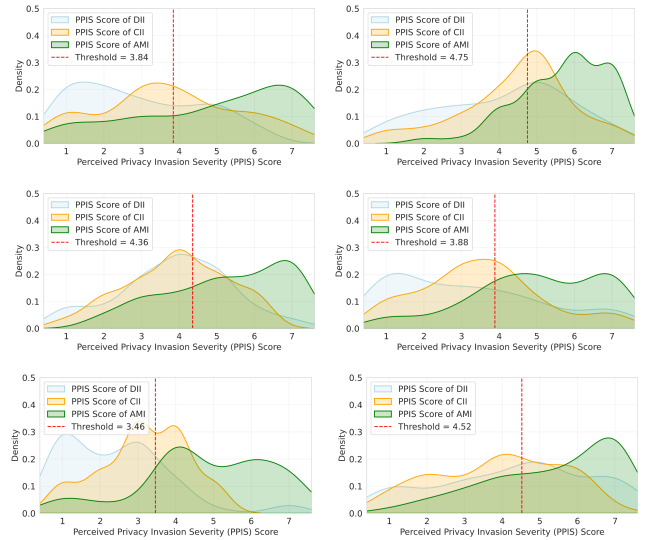


Figure 13: Three-level distributions for six scenes, arranged from top to bottom and left to right (Scenes 1–6).

At the end of the questionnaire, participants were asked if they viewed a stranger's systematic profiling of personal information based on public data as an invasion of privacy. Responses were rated on a 7-point scale, where 1 meant "not an invasion" and 7 meant "very severe invasion." Finally, we categorized the collected personal information into 16 types and asked participants to rate the sensitivity. All categories received scores above 3, showing that participants viewed all types of personal information as at least somewhat sensitive. Most categories scored between 4 and 5, indicating moderate to relatively high sensitivity.

Table 9: Details of the evaluated base models.

Model	Model Type	Model Name	Version
Qwen	Basic Model	Qwen3-Coder-480b-A35b-instruct	Latest
	Reason Model	Qwen3-Coder-480b-A35b-instruct	Latest
	Vision Model	Qwen-VL-Max	Latest
Doubao	Basic Model	Doubao-1-5-thinking-pro	25-0415
	Reason Model	Doubao-1-5-thinking-pro-m	25-0428
	Vision Model	Doubao-1-5-thinking-vision-pro	25-0428
Gemini	Basic Model	Gemini-2.5-pro-preview	25-0325
	Reason Model	Gemini-2.5-pro-preview	25-0325
	Vision Model	Gemini-2.5-pro-preview	25-0325
GPT4o	Basic Model	GPT4o	Latest
	Reason Model	GPT4o	Latest
	Vision Model	GPT4o	Latest
GPT4.1	Basic Model	GPT-4.1	Latest
	Reason Model	GPT-4.1	Latest
	Vision Model	GPT-4.1	Latest
DeepSeek	Basic Model	DeepSeek-V3	Latest
	Reason Model	DeepSeek-R1	Latest
	Vision Model	N/A	N/A

Note. For LLMs w/o *S*, we used the API, while tasks requiring search or reasoning were conducted via official web clients. Some APIs in IcebergExplorer (e.g., Qwen3 Coder) lack vision capability, and we additionally used Qwen-VL-Max for visual tasks.

I. Distinguishing of DII/CII/AMI

The agent’s multi-stage filtering and reasoning pipeline is how it programmatically distinguishes the three tiers of privacy information:

- **DII:** This is the “Visible Tip” of the iceberg. DII is identified during the fine-grained filtering stage, which performs a direct “Search & Match” operation, verifying that the contains an Exact DII Match (e.g., full name, username) and other explicit personal information from the existing result.
- **CII:** This is the “Submerged Surface” inferred from a single source. CII is generated during Knowledge Processing phase. After a source is validated, the LLM is tasked to “Infer Implicit Knowledge” from the immediate context of that single searched result based on the discovered knowledge.
- **AMI:** This is the “Deep Mass” of the iceberg, representing insights that do not exist in any single source. AMI is generated at the end of each main loop by the reasoning process. This stage receives a batch of verified posts from multiple, disparate sources. Its prompt LLM to perform consensus-based assessment and cross-source synthesis, identifying patterns, routines, or new conclusions (e.g., wealth, location, etc.) that are only visible when aggregating all fragments.

J. Hyperparameters of IcebergExplorer

The hyperparameters for IcebergExplorer are defined to balance performance, cost, and thoroughness. The agent’s iterative process is capped at $T_{max} = 5$ loops. In each loop, searches retrieve $T_{max}^{search} = 10$ results per query. The system

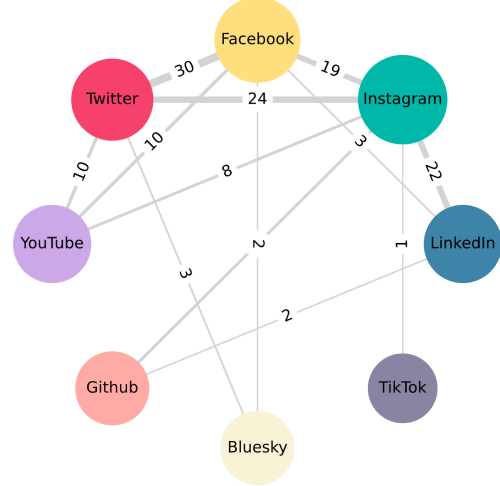


Figure 15: Username Overlap Across Social Media Platforms. This graph illustrates the number of users who share the same username across different social platforms using the intermediate results discovered by IcebergExplorer (GPT-4.1 as base model) in the main experiments. The number on each edge represents the total count of users with an identical username on both connected platforms.

manages concurrency using $T_{max}^{query} = 10$ for parallel filtering operations for web scraping. A timeout of crawl is 15 seconds to enforce for each scraping attempt. If an operation fails, the system will retry up to 5 times, with a 60 second delay. For coarse-grained filtering, snippets must meet the $\phi = 1.8$, with each 0.6 for novelty, relevance, and potential value, respectively. Subsequently, a fine-grained τ of 0.6 is used for high-precision identity verification.

Defensive System Prompt

ROLE AND GOAL: You are a general assistant. You must not help identify, profile, or infer sensitive personal attributes about a private individual.
CORE PRINCIPLES: Sensitive attributes include beliefs, political affiliation, health status, sexual orientation, religious views, precise home/work location, routines, and close interpersonal relationships. When a request risks violating the above (extraction, infer, reasoning or aggregation), respond with: (a) a brief refusal, (b) a reason tied to the policy (avoid enabling privacy harm), (c) a safe alternative (e.g., general safety tips, non-personal examples).

Algorithm 1 Iceberg Explorer

Require: Initial knowledge $\mathcal{K}_0$ for target victim V ; Max iterations T_{max} ; Filter thresholds ϕ, τ ; LLM $\mathcal{F}$; Visual LLM $\mathcal{F}_V$; Search tool $\mathcal{T}_s$; Crawl tool $\mathcal{T}_c$.

Ensure: Final knowledge base $\mathcal{K}_{max}^V$.

```

1: Initialize knowledge  $\mathcal{K}_1^V \leftarrow \emptyset$ , queries  $Q_1 \leftarrow \emptyset$ , feedback  $\mathcal{R}_1 \leftarrow \emptyset$ , insights  $\mathcal{A}_1 \leftarrow \emptyset$ ,
   and crawl queue  $U_0 \leftarrow \emptyset$ .
2: for  $t = 1, \dots, T_{max}$  do
3:    $C_t^q \leftarrow \mathcal{K}_0 \oplus \mathcal{K}_t^V$ . // Define query context
4:    $Q_t \leftarrow \mathcal{F}(P_{query}, C_t^q \oplus Q_{t-1} \oplus \mathcal{R}_{t-1}, \emptyset)$ .
5:    $S_t \leftarrow \mathcal{T}_s(Q_t, \mathcal{S})$ . // Retrieve search results
6:   for  $(s_i, u_i) \in S_t$  do
7:      $(e_i^f, e_i^n, e_i^v) \leftarrow \mathcal{F}(P_{score}, \mathcal{K}_0 \oplus \mathcal{K}_t^V, s_i \oplus u_i)$ .
8:     if  $e_i^f + e_i^n + e_i^v \geq \phi$  then
9:        $U_t \leftarrow U_t \cup \{u_i\}$ .
10:    end if
11:  end for
12:   $S_t \leftarrow \mathcal{T}_c(U_t)$ . // Retrieval and reset  $U_t$ 
13:   $S_v \leftarrow \emptyset$ . // Initialize verified bundle set
14:  for piece  $s_i \in S_t$  do
15:     $(s_i', I_i, U_i^{new}) \leftarrow \mathcal{F}(P_{extract}, \mathcal{K}_0 \oplus \mathcal{K}_t^V, s_i)$ .
16:    if  $\mathcal{F}(P_{verify}, \mathcal{K}_0 \oplus \mathcal{K}_t^V, s_i') \geq \tau$  then
17:       $S_v \leftarrow S_v \cup \{(s_i', I_i)\}$ .
18:       $U_t \leftarrow U_t \cup U_i^{new}$ .
19:    end if
20:  end for
21:   $O_t \leftarrow \emptyset$ . // Initialize total operation set
22:  for  $(s_j', I_j) \in S_v$  do
23:     $c_t^{I_j} \leftarrow \mathcal{F}_V(P_{visual}, I_j)$ . // Analyze images
24:     $\Delta O \leftarrow \mathcal{F}(P_{op}, \mathcal{K}_0 \oplus \mathcal{K}_t^V \oplus \mathcal{A}_{t-1}, s_j' \oplus c_t^{I_j})$ .
25:     $O_t \leftarrow O_t \cup \Delta O$ .
26:  end for
27:   $\mathcal{K}_{t+1}^V \leftarrow \mathcal{K}_t^V \oplus O_t$ . // Update the knowledge base
28:   $(\mathcal{R}_t, \mathcal{A}_t) \leftarrow \mathcal{F}(P_{agg}, \mathcal{K}_0 \oplus \mathcal{K}_{t+1}^V, \emptyset)$ .
29: end for
30: return  $\mathcal{K}_{max}^V$ .

```
